Directive (UE) 2016/1148 du Parlement européen et du Conseil du 6 juillet 2016 concernant des mesures destinées à assurer un niveau élevé commun de sécurité des réseaux et des systèmes d'information dans l'Union

JO L 194 du 19.7.2016, pp. 1–30 (BG, ES, CS, DA, DE, ET, EL, EN, FR, HR, IT, LV, LT, HU, MT, NL, PL, PT, RO, SK, SL, FI, SV)

No longer in force, Date of end of validity: 17/10/2024; abrogé par 32022L2555

ELI: http://data.europa.eu/eli/dir/2016/1148/oj

Languages, formats and link to OJ

Multilingual display

Text

DIRECTIVE (UE) 2016/1148 DU PARLEMENT EUROPÉEN ET DU CONSEIL

du 6 juillet 2016

concernant des mesures destinées à assurer un niveau élevé commun de sécurité des réseaux et des systèmes d'information dans l'Union

LE PARLEMENT EUROPÉEN ET LE CONSEIL DE L'UNION EUROPÉENNE,

vu le traité sur le fonctionnement de l'Union européenne, et notamment son article 114,

vu la proposition de la Commission européenne,

après transmission du projet d'acte législatif aux parlements nationaux,

vu l'avis du Comité économique et social européen ([1]),

statuant conformément à la procédure législative ordinaire ([2]),

considérant ce qui suit:

(1) Les réseaux et les services et systèmes d'information jouent un rôle crucial dans la société. Leur fiabilité et leur sécurité sont essentielles aux fonctions économiques et sociétales et notamment au fonctionnement du marché intérieur.

(2) L'ampleur, la fréquence et l'impact des incidents de sécurité ne cessent de croître et représentent une menace considérable pour le fonctionnement des réseaux et des systèmes d'information. Ces systèmes peuvent également devenir des cibles pour des actions intentionnelles malveillantes qui visent à la détérioration ou à l'interruption de leur fonctionnement. Ces incidents peuvent nuire à l'exercice d'activités économiques, entraîner des pertes financières importantes, entamer la confiance des utilisateurs et porter un grand préjudice à l'économie de l'Union.

(3) Les réseaux et les systèmes d'information, principalement l'internet, revêtent une importance essentielle pour la circulation transfrontalière des biens, des services et des personnes. En raison de ce caractère transnational, toute perturbation importante de ces systèmes, qu'elle soit intentionnelle ou non et indépendamment du lieu où elle se produit, peut avoir une incidence sur certains États membres et sur l'Union dans son ensemble. La sécurité des réseaux et des systèmes d'information est donc essentielle au fonctionnement harmonieux du marché intérieur.

(4) En se fondant sur les progrès significatifs accomplis au sein du Forum européen des États membres pour favoriser les discussions et les échanges de bonnes pratiques, et notamment l'élaboration de principes relatifs à la coopération européenne en cas de crise dans le domaine de la cybersécurité, il convient de constituer un groupe de coopération réunissant des représentants des États membres, de la Commission et de l'Agence de l'Union européenne chargée de la sécurité des réseaux et de l'information (ENISA) ayant pour mission de soutenir et de faciliter la coopération stratégique entre les États membres en ce qui concerne la sécurité des réseaux et des systèmes d'information. Pour que ce groupe soit efficace et ouvert à tous, il est essentiel que tous les États membres soient dotés d'un minimum de moyens et d'une stratégie garantissant un niveau élevé de sécurité des réseaux et des systèmes d'information sur leur territoire. De plus, les opérateurs de services essentiels et les fournisseurs de service numérique devraient être soumis à des exigences en matière de sécurité et de notification, afin de promouvoir une culture de gestion des risques et de faire en sorte que les incidents les plus graves soient signalés.

(5) Les moyens existants ne sont pas suffisants pour assurer un niveau élevé de sécurité des réseaux et des systèmes d'information dans l'Union. Les niveaux de préparation sont très différents selon les États membres, ce qui se traduit par une fragmentation des approches dans l'Union. Les niveaux de protection des consommateurs et des entreprises sont donc inégaux, ce qui porte atteinte au niveau global de sécurité des réseaux et des systèmes d'information dans l'Union. En outre, l'absence d'exigences communes applicables aux opérateurs de services essentiels et aux fournisseurs de service numérique rend impossible la création d'un mécanisme général et efficace de coopération au niveau de l'Union. Les universités et les centres de recherche ont un rôle déterminant à jouer dans la stimulation de la recherche, du développement et de l'innovation dans ces domaines.

(6) Il faut donc, pour faire face efficacement aux défis que pose la sécurité des réseaux et des systèmes d'information, adopter une approche globale au niveau de l'Union qui couvrira des exigences minimales communes en matière de renforcement des capacités et de planification, l'échange d'informations, la coopération et des exigences communes en matière de sécurité pour les opérateurs de services essentiels et les fournisseurs de service numérique. Cependant, il n'est pas interdit aux opérateurs de services essentiels et aux fournisseurs de service numérique de mettre en œuvre des mesures de sécurité plus strictes que celles prévues par la présente directive.

(7) Pour que tous les incidents et risques pertinents soient couverts, il convient que la présente directive s'applique tant aux opérateurs de services essentiels qu'aux fournisseurs de service numérique. Cependant, les obligations imposées aux opérateurs de services essentiels et aux fournisseurs de service numérique ne devraient pas s'appliquer aux entreprises qui fournissent des réseaux de communications publics ou des services de communications électroniques accessibles au public au sens de la directive 2002/21/CE du Parlement européen et du

Conseil ([3]), qui sont soumises aux exigences particulières relatives à la sécurité et à l'intégrité énoncées dans ladite directive, ni aux prestataires de services de confiance au sens du règlement (UE) n° 910/2014 du Parlement européen et du Conseil ([4]), qui sont soumis aux exigences de sécurité énoncées dans ledit règlement.

(8) La présente directive devrait s'entendre sans préjudice de la possibilité donnée à chaque État membre d'adopter les mesures nécessaires pour garantir la protection des intérêts essentiels de sa sécurité, assurer l'action publique et la sécurité publique et permettre la recherche, la détection et la poursuite d'infractions pénales. Conformément à l'article 346 du traité sur le fonctionnement de l'Union européenne, aucun État membre n'est tenu de fournir des renseignements dont il estimerait la divulgation contraire aux intérêts essentiels de sa sécurité. À cet égard, la décision 2013/488/UE du Conseil ([5]) et les accords de non-divulgation, ou les accords de non-divulgation informelle tels que le protocole d'échange d'information «Traffic Light Protocol», sont pertinents.

(9) Certains secteurs de l'économie sont déjà réglementés ou peuvent l'être à l'avenir par des actes juridiques sectoriels de l'Union comportant des règles relatives à la sécurité des réseaux et des systèmes d'information. Chaque fois que ces actes juridiques de l'Union contiennent des dispositions imposant des exigences relatives à la sécurité des réseaux et des systèmes d'information ou à la notification des incidents, ces dispositions devraient s'appliquer si elles contiennent des exigences ayant un effet au moins équivalent à celui des obligations figurant dans la présente directive. Les États membres devraient alors appliquer les dispositions des actes juridiques sectoriels concernés de l'Union, notamment celles relatives à la compétence, et ils ne devraient pas mettre en œuvre le processus d'identification des opérateurs de services essentiels tel qu'il est défini par la présente directive. À cet égard, les États membres devraient fournir à la Commission des informations sur l'application de telles dispositions de *lex specialis*. Pour établir si les exigences relatives à la sécurité des réseaux et des systèmes d'information et à la notification des incidents prévues par les actes juridiques sectoriels de l'Union sont équivalentes à celles qui sont énoncées dans la présente directive, il ne devrait être tenu compte que des dispositions des actes juridiques pertinents de l'Union et de leur application dans les États membres.

(10) Dans le secteur des transports par voie d'eau, les exigences en matière de sécurité imposées par des actes juridiques de l'Union aux compagnies, aux navires, aux installations portuaires, aux ports et aux services de gestion du trafic maritime portent sur l'ensemble des activités, y compris les systèmes de radio et de télécommunications, les systèmes informatiques et les réseaux. Une partie des procédures auxquelles il est obligatoire de se conformer concerne le signalement de tous les incidents et devrait donc être considérée comme une *lex specialis*, dans la mesure où ces exigences sont au moins équivalentes aux dispositions correspondantes de la présente directive.

(11) Lors de l'identification des opérateurs dans le secteur des transports par voie d'eau, les États membres devraient prendre en compte les codes internationaux et les lignes directrices existants et futurs élaborés notamment par l'Organisation maritime internationale, en vue d'offrir une approche cohérente aux différents opérateurs maritimes.

(12) La réglementation et la surveillance dans les secteurs de la banque et des infrastructures des marchés financiers sont hautement harmonisées au niveau de l'Union au moyen de dispositions du droit primaire et du droit dérivé de l'Union et de normes élaborées en collaboration avec les

autorités européennes de surveillance. Au sein de l'union bancaire, l'application et la surveillance de ces exigences sont assurées par le mécanisme de surveillance unique. Pour les États membres qui ne font pas partie de l'union bancaire, ces fonctions sont assurées par leurs organes nationaux de réglementation bancaire compétents. Dans d'autres domaines de la réglementation du secteur financier, le système européen de surveillance financière garantit également un degré élevé d'uniformité et de convergence des pratiques en matière de surveillance. L'Autorité européenne des marchés financiers joue également un rôle direct de surveillance pour certaines entités, à savoir les agences de notation de crédit et les référentiels centraux.

(13) Le risque opérationnel est un élément crucial de la réglementation et de la surveillance prudentielles dans les secteurs de la banque et des infrastructures de marchés financiers. Il porte sur toutes les activités, notamment la sécurité, l'intégrité et la résilience des réseaux et des systèmes d'information. Les exigences concernant ces systèmes, qui vont souvent au-delà des exigences prévues en vertu de la présente directive, sont définies dans un certain nombre d'actes juridiques de l'Union, y compris les règles concernant l'accès à l'activité des établissements de crédit et la surveillance prudentielle des établissements de crédit et des entreprises d'investissement, ainsi que les règles concernant les exigences prudentielles applicables aux établissements de crédit et aux entreprises d'investissement, parmi lesquelles figurent les exigences concernant le risque opérationnel; les règles concernant les marchés d'instruments financiers, qui comprennent des exigences relatives à l'évaluation des risques pour les entreprises d'investissement et les marchés réglementés; les règles relatives aux instruments dérivés de gré à gré, aux contreparties centrales et aux référentiels centraux, parmi lesquelles figurent les exigences concernant le risque opérationnel applicables aux contreparties centrales et aux référentiels centraux; et les règles concernant l'amélioration du règlement de titres dans l'Union et les dépositaires centraux de titres, parmi lesquelles figurent les exigences concernant le risque opérationnel. En outre, les obligations en matière de notification des incidents font partie des pratiques de surveillance normales dans le secteur financier et sont souvent incluses dans les manuels de surveillance. Les États membres devraient tenir compte de ces règles et exigences au moment d'appliquer la *lex specialis*.

(14) Comme le fait observer la Banque centrale européenne dans son avis du 25 juillet 2014 ([6]), la présente directive n'a pas d'incidence sur le régime mis en place dans le droit de l'Union pour la surveillance des systèmes de paiement et de règlement dans le cadre de l'Eurosystème. Il serait opportun que les autorités chargées de cette surveillance procèdent à des échanges d'expériences sur les questions relatives à la sécurité des réseaux et des systèmes d'information avec les autorités compétentes en vertu de la présente directive. La même considération s'applique aux membres du Système européen de banques centrales qui n'appartiennent pas à la zone euro et qui exercent cette surveillance des systèmes de paiement et de règlement sur la base de leurs dispositions législatives et réglementaires nationales.

(15) Une place de marché en ligne permet aux consommateurs et aux professionnels de conclure des contrats de vente ou de service en ligne avec des professionnels et c'est la destination finale pour la conclusion desdits contrats. Elle ne devrait pas concerner les services en ligne qui ne servent que d'intermédiaires pour des services fournis par un tiers à travers lequel un contrat peut en définitive être conclu. Elle ne devrait donc pas concerner les services en ligne qui comparent le prix de certains produits ou services de plusieurs professionnels, avant de réorienter l'utilisateur vers le professionnel choisi en vue de l'achat du produit. Parmi les

services informatiques fournis par la place de marché en ligne peuvent figurer le traitement de transactions, l'agrégation de données ou le profilage d'utilisateurs. Les magasins d'applications en ligne, qui fonctionnent comme des magasins en ligne permettant la distribution numérique d'applications ou de logiciels émanant de tiers, doivent s'entendre comme étant un type de place de marché en ligne.

(16) Un moteur de recherche en ligne permet à l'utilisateur d'effectuer des recherches sur, en principe, tous les sites internet sur la base d'une requête lancée sur n'importe quel sujet. Il peut aussi se limiter aux sites internet dans une langue donnée. La définition d'un moteur de recherche en ligne donnée par la présente directive ne devrait pas s'appliquer aux fonctions de recherche qui se limitent au contenu d'un site internet spécifique, indépendamment de la question de savoir si la fonction de recherche est assurée par un moteur de recherche externe. Elle ne devrait pas non plus concerner les services en ligne qui comparent le prix de certains produits ou services de différents professionnels et qui réorientent ensuite l'utilisateur vers le professionnel choisi en vue de l'achat du produit.

(17) Les services d'informatique en nuage couvrent un vaste éventail d'activités qui peuvent être fournies selon différents modèles. Aux fins de la présente directive, les termes «services d'informatique en nuage» couvrent des services qui permettent l'accès à un ensemble modulable et variable de ressources informatiques pouvant être partagées. Ces ressources informatiques comprennent des ressources telles que les réseaux, serveurs et autres infrastructures, le stockage, les applications et les services. Le terme «modulable» renvoie aux ressources informatiques qui sont attribuées d'une manière souple par le fournisseur de services en nuage, indépendamment de la localisation géographique de ces ressources, pour gérer les fluctuations de la demande. Les termes «ensemble variable» sont utilisés pour décrire les ressources informatiques qui sont mobilisées et libérées en fonction de la demande pour pouvoir augmenter ou réduire rapidement les ressources disponibles en fonction de la charge de travail. Les termes «pouvant être partagées» sont utilisés pour décrire les ressources informatiques qui sont mises à disposition de nombreux utilisateurs qui partagent un accès commun au service, le traitement étant effectué séparément pour chaque utilisateur bien que le service soit fourni à partir du même équipement électronique.

(18) La fonction d'un point d'échange internet (IXP) est d'interconnecter des réseaux. Un IXP ne fournit pas d'accès à un réseau et n'agit pas en tant que fournisseur ou opérateur de transit. Un IXP ne fournit pas non plus d'autres services non liés à l'interconnexion, sans que cela empêche l'exploitant d'un IXP de fournir des services non liés. Un IXP a pour fonction d'interconnecter des réseaux qui sont distincts d'un point de vue technique et organisationnel. Les termes «système autonome» sont utilisés pour désigner un réseau autonome sur le plan technique.

(19) Les États membres devraient être chargés d'établir quelles sont les entités qui remplissent les critères de la définition d'un opérateur de services essentiels. Dans le souci d'assurer une démarche cohérente, la définition d'un opérateur de services essentiels devrait être appliquée de manière cohérente par tous les États membres. À cette fin, la présente directive prévoit l'évaluation des entités actives dans les secteurs et sous-secteurs spécifiques, l'établissement d'une liste de services essentiels, la prise en considération d'une liste commune des facteurs transsectoriels pour déterminer si un incident potentiel aurait un effet disruptif important, un processus de consultation faisant intervenir les États membres concernés dans le cas d'entités fournissant des services dans plus d'un État membre, et le soutien apporté par le groupe de coopération dans le cadre du processus d'identification. Afin qu'il soit fidèlement tenu compte

des éventuels changements intervenus sur le marché, il convient que la liste des opérateurs identifiés soit régulièrement revue par les États membres et mise à jour si nécessaire. Enfin, les États membres devraient communiquer à la Commission les informations nécessaires à l'appréciation de la mesure dans laquelle cette méthode commune a permis de procéder à une application cohérente de la définition par les États membres.

(20) Dans le cadre du processus d'identification des opérateurs de services essentiels, il convient que les États membres évaluent, au moins pour chaque sous-secteur visé par la présente directive, quels services doivent être considérés comme essentiels au maintien de fonctions sociétales et économiques critiques et jugent si les entités qui sont énumérées pour les secteurs et sous-secteurs visés dans la présente directive et qui fournissent ces services remplissent les critères requis pour l'identification des opérateurs. Pour apprécier si une entité fournit un service qui est essentiel au maintien de fonctions sociétales ou économiques critiques, il suffit d'examiner si cette entité fournit un service figurant dans la liste des services essentiels. En outre, il y a lieu de démontrer que la fourniture du service essentiel dépend des réseaux et des systèmes d'information. Enfin, lorsqu'ils évaluent si un incident aurait un effet disruptif important sur la fourniture du service, les États membres devraient tenir compte d'un certain nombre de facteurs transsectoriels ainsi que, le cas échéant, de facteurs sectoriels.

(21) Aux fins d'identification des opérateurs de services essentiels, l'établissement dans un État membre suppose l'exercice effectif et réel d'une activité au moyen d'une installation stable. La forme juridique retenue pour un tel établissement, qu'il s'agisse d'une succursale ou d'une filiale ayant la personnalité juridique, n'est pas déterminante à cet égard.

(22) Il est possible que les entités relevant des secteurs et sous-secteurs visés dans la présente directive fournissent des services essentiels et des services non essentiels. Par exemple, dans le secteur du transport aérien, les aéroports fournissent des services qu'un État membre pourrait considérer comme essentiels, tels que la gestion des pistes, mais aussi un certain nombre de services qui pourraient être considérés comme non essentiels, tels que la mise à disposition de zones commerciales. Les opérateurs de services essentiels ne devraient être soumis aux exigences de sécurité spécifiques que pour les services qui sont jugés essentiels. Aux fins de l'identification des opérateurs, les États membres devraient dès lors établir une liste des services qui sont considérés comme essentiels.

(23) La liste des services devrait contenir tous les services fournis sur le territoire d'un État membre donné qui satisfont aux exigences prévues par la présente directive. Les États membres devraient être en mesure de compléter la liste existante en y incluant de nouveaux services. La liste des services devrait servir de point de référence aux États membres, en permettant d'identifier les opérateurs de services essentiels. Son objectif est d'identifier les types de services essentiels dans un secteur donné visé dans la présente directive, en les distinguant ainsi des activités non essentielles dont une entité active dans un secteur donné pourrait avoir la responsabilité. La liste des services établie par chaque État membre constituerait une contribution supplémentaire à l'évaluation des pratiques réglementaires de chaque État membre dans le but d'assurer la cohérence générale du processus d'identification dans les États membres.

(24) Aux fins du processus d'identification, lorsqu'une entité fournit un service essentiel dans deux ou plusieurs États membres, les États membres en question devraient entamer des consultations bilatérales ou multilatérales entre eux. Ce processus de consultation est destiné à les aider à évaluer le caractère critique de l'opérateur en termes d'incidence transfrontalière en permettant

ainsi à chaque État membre concerné de présenter son point de vue sur les risques associés aux services fournis. Lors de ce processus, les États membres concernés devraient tenir compte de leurs avis respectifs et ils devraient pouvoir solliciter l'assistance du groupe de coopération à cet égard.

(25) À la suite du processus d'identification, les États membres devraient adopter des mesures nationales visant à établir quelles entités sont soumises à des obligations en matière de sécurité des réseaux et des systèmes d'information. Ce résultat pourrait être atteint par l'adoption d'une liste énumérant tous les opérateurs de services essentiels ou par l'adoption de mesures nationales assorties de critères objectifs quantifiables, tels que la production de l'opérateur ou le nombre d'utilisateurs, qui permettent de déterminer quelles sont les entités qui sont soumises à des obligations en matière de sécurité des réseaux et des systèmes d'information. Les mesures nationales, que ces mesures soient préexistantes ou qu'elles soient adoptées dans le cadre de la présente directive, devraient inclure toutes les mesures juridiques, administratives et politiques permettant d'identifier des opérateurs de services essentiels conformément à la présente directive.

(26) Afin de montrer l'importance, par rapport au secteur concerné, des opérateurs identifiés de services essentiels, les États membres devraient tenir compte du nombre et de la taille de ces opérateurs, par exemple en termes de parts de marché ou de quantité produite ou transportée, sans être contraints de divulguer des informations susceptibles de révéler l'identité des opérateurs identifiés.

(27) Afin de déterminer si un incident est susceptible d'avoir un effet disruptif important sur la fourniture d'un service essentiel, les États membres devraient prendre en compte plusieurs facteurs différents, tels que le nombre d'utilisateurs s'appuyant sur ce service à des fins privées ou professionnelles. Ce service peut s'utiliser de manière directe, indirecte ou à travers un intermédiaire. Lorsqu'ils évaluent l'impact qu'un incident pourrait avoir, du point de vue de son intensité et de sa durée, sur les fonctions économiques et sociétales ou sur la sûreté publique, les États membres devraient également estimer le temps qui pourrait s'écouler avant que l'interruption du service ne commence à avoir un impact négatif.

(28) Afin de déterminer si un incident est susceptible d'avoir un effet disruptif important sur la fourniture d'un service essentiel, il convient, outre les facteurs transsectoriels, de prendre également en compte des facteurs sectoriels. Ces facteurs pourraient inclure, pour les fournisseurs d'énergie, le volume ou la proportion d'énergie produite au niveau national; pour les fournisseurs de pétrole, le volume journalier; pour le transport aérien, y compris les aéroports et les transporteurs aériens, le transport ferroviaire et les ports maritimes, la proportion du volume de trafic national et le nombre de passagers ou d'opérations de fret par an; pour les infrastructures bancaires ou des marchés financiers, leur importance systémique sur la base de leurs actifs totaux ou du ratio entre ces actifs totaux et le PIB; pour le secteur de la santé, le nombre annuel de patients pris en charge par le prestataire; pour la production, le traitement et la distribution d'eau, le volume d'eau, le nombre et les types d'utilisateurs servis, y compris, par exemple, des hôpitaux, des organismes de service public ou des particuliers, ainsi que l'existence d'autres sources d'approvisionnement en eau couvrant la même zone géographique.

(29) Pour atteindre un niveau élevé de sécurité des réseaux et des systèmes d'information et le maintenir, chaque État membre devrait se doter d'une stratégie nationale en matière de sécurité

des réseaux et des systèmes d'information définissant les objectifs stratégiques et les actions politiques concrètes à mettre en œuvre.

(30) Compte tenu des divergences entre les structures de gouvernance nationales et en vue de sauvegarder les accords existants au niveau sectoriel ou les autorités de surveillance et de régulation de l'Union et d'éviter les doubles emplois, les États membres devraient pouvoir désigner plusieurs autorités nationales compétentes chargées d'accomplir les tâches liées à la sécurité des réseaux et des systèmes d'information des opérateurs de services essentiels et des fournisseurs de service numérique dans le cadre de la présente directive.

(31) Afin de faciliter la coopération et la communication transfrontalières et pour permettre la mise en œuvre effective de la présente directive, il est nécessaire que chaque État membre, sans préjudice des accords sectoriels de régulation, désigne un point de contact national unique chargé de coordonner les tâches liées à la sécurité des réseaux et des systèmes d'information et de la coopération transfrontalière au niveau de l'Union. Les autorités compétentes et les points de contact uniques devraient être dotés de ressources techniques, financières et humaines suffisantes pour pouvoir s'acquitter de manière effective et efficace des tâches qui leur sont dévolues et atteindre ainsi les objectifs de la présente directive. Étant donné que la présente directive vise à améliorer le fonctionnement du marché intérieur par l'instauration de la confiance, les organismes des États membres doivent être en mesure de coopérer efficacement avec les acteurs économiques et être structurés en conséquence.

(32) Les autorités compétentes ou les centres de réponse aux incidents de sécurité informatique (CSIRT) devraient recevoir les notifications d'incidents. Les points de contact uniques ne devraient pas recevoir directement toutes les notifications d'incidents, à moins qu'ils n'agissent également en qualité d'autorité compétente ou de CSIRT. Une autorité compétente ou un CSIRT devrait cependant pouvoir charger le point de contact unique de transmettre les notifications d'incidents aux points de contact uniques d'autres États membres touchés.

(33) Pour assurer l'information effective des États membres et de la Commission, un rapport de synthèse devrait être soumis par le point de contact unique au groupe de coopération et devrait être rendu anonyme afin de préserver la confidentialité des notifications et l'identité des opérateurs de services essentiels et des fournisseurs de service numérique, étant donné que les données relatives à l'identité des entités qui sont à l'origine de la notification ne sont pas requises pour l'échange de bonnes pratiques au sein du groupe de coopération. Le rapport de synthèse devrait contenir des informations sur le nombre de notifications reçues ainsi qu'une indication de la nature des incidents notifiés, telle que les types d'atteintes à la sécurité, leur gravité ou leur durée.

(34) Les États membres devraient disposer de moyens suffisants, sur les plans technique et organisationnel, pour prévenir et détecter les incidents et risques liés aux réseaux et systèmes d'information et prendre les mesures d'intervention et d'atténuation nécessaires. Les États membres devraient dès lors veiller à disposer de CSIRT, également connus sous la dénomination de centres de réponse aux urgences informatiques (CERT), opérationnels et conformes aux exigences essentielles afin de garantir l'existence de moyens effectifs et compatibles pour gérer les incidents et les risques et d'assurer une coopération efficace au niveau de l'Union. Afin que tous les types d'opérateurs de services essentiels et de fournisseurs de service numérique puissent bénéficier de ces moyens et de cette coopération, les États membres devraient veiller à ce que tous les types soient couverts par un CSIRT désigné. Compte tenu de l'importance de la coopération internationale en matière de cybersécurité, les

CSIRT devraient pouvoir participer à des réseaux de coopération internationaux en plus du réseau des CSIRT institué par la présente directive.

(35) Étant donné que la plupart des réseaux et des systèmes d'information sont exploités par des intérêts privés, il est essentiel d'établir une coopération entre secteur public et secteur privé. Il convient d'encourager les opérateurs de services essentiels et les fournisseurs de service numérique à mettre en place leurs propres mécanismes informels de coopération pour garantir la sécurité des réseaux et des systèmes d'information. Le groupe de coopération devrait pouvoir inviter les parties prenantes concernées aux discussions, s'il y a lieu. Il est essentiel, pour encourager effectivement le partage des informations et des bonnes pratiques, de veiller à ce que les opérateurs de services essentiels et les fournisseurs de service numérique qui participent à ces échanges ne soient pas désavantagés du fait même de leur coopération.

(36) L'ENISA devrait assister les États membres et la Commission en mettant à leur disposition ses connaissances et ses conseils et en facilitant l'échange des bonnes pratiques. En particulier, la Commission devrait consulter l'ENISA et les États membres devraient pouvoir la consulter en ce qui concerne l'application de la présente directive. Afin de développer les moyens disponibles et la connaissance dans les États membres, le groupe de coopération devrait aussi être un outil d'échange des bonnes pratiques et d'examen des capacités et de l'état de préparation des États membres et, à titre volontaire, il devrait aider ses membres à évaluer leurs stratégies nationales en matière de sécurité des réseaux et des systèmes d'information, à renforcer leurs capacités et à évaluer les exercices relatifs à la sécurité des réseaux et des systèmes d'information.

(37) Le cas échéant, les États membres devraient pouvoir utiliser ou adapter les structures organisationnelles ou les stratégies existantes aux fins de l'application de la présente directive.

(38) Les tâches respectives du groupe de coopération et de l'ENISA sont interdépendantes et complémentaires. D'une manière générale, l'ENISA devrait aider le groupe de coopération dans l'accomplissement de ses tâches, conformément à l'objectif de l'ENISA défini au règlement (UE) n° 526/2013 du Parlement européen et du Conseil ([7]), qui consiste à assister les institutions, organes et organismes de l'Union et les États membres dans la mise en œuvre des politiques nécessaires pour satisfaire aux exigences légales et réglementaires requises au titre des actes juridiques existants et à venir de l'Union en matière de sécurité des réseaux et des systèmes d'information. En particulier, l'ENISA devrait fournir une assistance dans les domaines qui correspondent à ses propres missions telles que définies dans le règlement (UE) n° 526/2013, à savoir l'analyse des stratégies en matière de sécurité des réseaux et des systèmes d'information, le soutien à l'organisation et à la réalisation d'exercices de l'Union portant sur la sécurité des réseaux et des systèmes d'information et l'échange d'informations et de bonnes pratiques en matière de sensibilisation et de formation. L'ENISA devrait également participer à l'élaboration de lignes directrices pour la définition de critères sectoriels permettant d'établir l'ampleur de l'impact d'un incident.

(39) Afin de promouvoir la sécurité renforcée des réseaux et des systèmes d'information, il convient que le groupe de coopération coopère, le cas échéant, avec les institutions, organes et organismes compétents de l'Union en vue d'échanger le savoir-faire et les bonnes pratiques et de fournir des conseils sur les aspects relatifs à la sécurité des réseaux et des systèmes d'information qui pourraient avoir une incidence sur leurs activités, dans le respect des dispositions en vigueur en matière d'échange d'informations restreintes. Dans sa coopération

avec les services répressifs concernant les questions relatives à la sécurité des réseaux et des systèmes d'information susceptibles d'avoir une incidence sur leurs activités, le groupe de coopération devrait respecter les canaux d'information existants et les réseaux établis.

(40) Les informations relatives aux incidents s'avèrent de plus en plus précieuses pour le grand public et pour les entreprises, en particulier pour les petites et moyennes entreprises. Dans certains cas, ces informations sont déjà fournies par des sites internet au niveau national, dans la langue du pays et elles sont centrées principalement sur les incidents et événements ayant une dimension nationale. Étant donné que les entreprises exercent de plus en plus d'activités transfrontalières et que les citoyens recourent aux services en ligne, il convient que les informations concernant les incidents soient fournies sous forme agrégée au niveau de l'Union. Le secrétariat du réseau des CSIRT est encouragé à tenir à jour un site internet ou à héberger une page spéciale sur un site internet existant, mettant à la disposition du grand public des informations générales sur les principaux incidents qui sont survenus dans toute l'Union, en mettant l'accent sur les intérêts et les besoins des entreprises. Les CSIRT participant au réseau des CSIRT sont encouragés à fournir, à titre volontaire, les informations destinées à être publiées sur ce site internet sans que cela ne comporte d'informations confidentielles ou sensibles.

(41) Lorsque des informations sont considérées comme confidentielles conformément à la réglementation nationale ou de l'Union en matière de secret des affaires, cette confidentialité devrait être garantie lors de l'exécution des activités et de la réalisation des objectifs énoncés par la présente directive.

(42) Les exercices qui simulent des scénarios d'incidents en temps réel sont essentiels pour tester l'état de préparation et la coopération des États membres quant à la sécurité des réseaux et des systèmes d'information. Le cycle d'exercices CyberEurope coordonné par l'ENISA avec la participation des États membres est un outil utile pour réaliser des tests et établir des recommandations sur la manière dont la gestion d'incidents au niveau de l'Union devrait s'améliorer au fil du temps. Étant donné que les États membres ne sont pas actuellement tenus de programmer des exercices ni d'y participer, la création du réseau des CSIRT dans le cadre de la présente directive devrait leur permettre de prendre part à des exercices sur la base d'une planification précise et de choix stratégiques. Le groupe de coopération institué par la présente directive devrait examiner les décisions stratégiques concernant les exercices, en particulier, mais pas exclusivement, pour ce qui est de leur régularité et de la conception des scénarios. L'ENISA devrait, conformément à son mandat, soutenir l'organisation et la tenue d'exercices dans l'ensemble de l'Union en fournissant ses connaissances et ses conseils au groupe de coopération et au réseau des CSIRT.

(43) Étant donné que les problèmes de sécurité affectant les réseaux et les systèmes d'information ont une dimension mondiale, il est nécessaire de renforcer la coopération internationale pour améliorer les normes de sécurité et les échanges d'informations et pour promouvoir une approche commune au niveau mondial en ce qui concerne les problèmes de sécurité.

(44) C'est, dans une large mesure, aux opérateurs de services essentiels et aux fournisseurs de service numérique qu'incombe la responsabilité de garantir la sécurité des réseaux et des systèmes d'information. Il convient de promouvoir et de faire évoluer, au moyen d'exigences réglementaires appropriées et de pratiques sectorielles volontaires, une culture de la gestion des risques impliquant une analyse des risques et l'application de mesures de sécurité adaptées aux risques encourus. Il est aussi essentiel d'établir un socle commun de confiance pour que le

groupe de coopération et le réseau des CSIRT fonctionnent réellement et que la coopération de la part de tous les États membres soit effective.

(45) La présente directive s'applique uniquement aux administrations publiques qui sont identifiées en tant qu'opérateurs de services essentiels. Il est donc de la responsabilité des États membres de garantir la sécurité des réseaux et des systèmes d'information des administrations publiques ne relevant pas du champ d'application de la présente directive.

(46) Parmi les mesures de gestion des risques figurent celles permettant d'identifier tous les risques d'incidents, de prévenir, de repérer et de gérer les incidents et d'en atténuer l'impact. La sécurité des réseaux et des systèmes d'information inclut la sécurité des données stockées, transmises et traitées.

(47) Les autorités compétentes devraient conserver la capacité d'adopter des lignes directrices relatives aux circonstances dans lesquelles les opérateurs de services essentiels sont tenus de notifier les incidents.

(48) De nombreuses entreprises dans l'Union s'appuient, pour délivrer leurs services, sur des fournisseurs de service numérique. Étant donné que certains services numériques pourraient représenter une ressource importante pour leurs utilisateurs, y compris des opérateurs de services essentiels, et que beaucoup de ces utilisateurs pourraient ne pas toujours disposer de solutions de rechange, il convient que la présente directive s'applique également aux fournisseurs de ce type de services. La sécurité, la continuité et la fiabilité du type de services numériques visés dans la présente directive sont essentielles pour le bon fonctionnement de nombreuses entreprises. La perturbation d'un tel service numérique pourrait empêcher la fourniture d'autres services qui s'appuient sur celui-ci et avoir dès lors une incidence sur des fonctions économiques et sociétales clés dans l'Union. De tels services numériques pourraient par conséquent revêtir une importance cruciale pour le bon fonctionnement des entreprises qui en dépendent et, par ailleurs, pour la participation de ces entreprises au marché intérieur et aux échanges transfrontaliers dans l'ensemble de l'Union. Les fournisseurs de service numérique relevant de la présente directive sont ceux qui sont considérés comme offrant des services numériques sur lesquels de nombreuses entreprises de l'Union s'appuient de plus en plus.

(49) Les fournisseurs de service numérique devraient garantir un niveau de sécurité à la hauteur du risque qui menace la sécurité des services numériques qu'ils proposent, compte tenu de l'importance de leurs services pour les activités d'autres entreprises au sein de l'Union. Dans la pratique, le degré de risque pour les opérateurs de services essentiels, qui sont souvent cruciaux pour le maintien de fonctions sociétales et économiques critiques, est plus élevé que pour les fournisseurs de service numérique. Par conséquent, les exigences en matière de sécurité imposées aux fournisseurs de service numérique devraient être moins strictes. Les fournisseurs de service numérique devraient rester libres de prendre les mesures qu'ils jugent appropriées pour gérer les risques qui menacent la sécurité de leurs réseaux et systèmes d'information. En raison du caractère transfrontalier de leurs activités, les fournisseurs de service numérique devraient faire l'objet d'une approche plus harmonisée au niveau de l'Union. La définition et la mise en œuvre de ces mesures devraient être facilitées au moyen d'actes d'exécution.

(50) Alors que les fabricants de matériel et les développeurs de logiciels ne sont pas des opérateurs de services essentiels ou des fournisseurs de service numérique, leurs produits renforcent la sécurité des réseaux et des systèmes d'information. Dès lors, ils jouent un rôle important en permettant aux opérateurs de services essentiels et aux fournisseurs de service numérique de

sécuriser leurs réseaux et systèmes d'information. Ce matériel et ces logiciels font déjà l'objet de règles existantes sur la responsabilité du fait des produits.

(51)Les mesures techniques et organisationnelles imposées aux opérateurs de services essentiels et aux fournisseurs de service numérique ne devraient pas impliquer la conception, le développement ou la fabrication selon des modalités précises d'un produit commercial particulier relevant des technologies de l'information et de la communication.

(52)Les opérateurs de services essentiels et les fournisseurs de service numérique devraient garantir la sécurité des réseaux et des systèmes d'information qu'ils utilisent. Il s'agit principalement de réseaux et de systèmes d'information privés qui sont gérés par leurs propres services informatiques ou dont la gestion de la sécurité a été sous-traitée. Les exigences en matière de sécurité et de notification devraient s'appliquer aux opérateurs de services essentiels et aux fournisseurs de service numérique concernés, que la maintenance de leurs réseaux et systèmes d'information soit assurée en interne ou qu'elle soit sous-traitée.

(53)Pour éviter que la charge financière et administrative imposée aux opérateurs de services essentiels et aux fournisseurs de service numérique ne soit excessive, il convient que les exigences soient proportionnées aux risques que présentent le réseau et le système d'information concernés, compte tenu de l'état le plus avancé de la technique en ce qui concerne ces mesures. Dans le cas des fournisseurs de service numérique, ces exigences ne devraient pas être applicables aux microentreprises et aux petites entreprises.

(54)Les administrations publiques des États membres qui utilisent des services proposés par des fournisseurs de service numérique, notamment des services d'informatique en nuage, pourraient vouloir exiger de ces fournisseurs des mesures de sécurité supplémentaires allant au-delà de ce que ceux-ci proposeraient d'ordinaire dans le respect des exigences de la présente directive. Elles devraient pouvoir l'obtenir en imposant des obligations contractuelles.

(55)Les définitions des termes «place de marché en ligne», «moteur de recherche en ligne» et «services d'informatique en nuage» énoncées dans la présente directive servent aux fins spécifiques de la présente directive et sont sans préjudice d'autres instruments.

(56)La présente directive ne devrait pas empêcher les États membres d'adopter des mesures nationales obligeant les organismes du secteur public à fixer des exigences spécifiques en matière de sécurité lorsqu'ils passent des contrats pour des services d'informatique en nuage. De telles mesures nationales devraient s'appliquer à l'organisme du secteur public concerné et non au fournisseur de services d'informatique en nuage.

(57)Étant donné les différences fondamentales qui existent entre les opérateurs de services essentiels, notamment leur lien direct avec des infrastructures physiques, et les fournisseurs de service numérique, notamment le caractère transfrontalier de leurs activités, la présente directive devrait adopter une approche différenciée en ce qui concerne le niveau d'harmonisation à prévoir pour ces deux groupes d'entités. Pour les opérateurs de services essentiels, les États membres devraient pouvoir identifier les opérateurs concernés et imposer des exigences plus strictes que celles énoncées dans la présente directive. Les États membres ne devraient pas identifier les fournisseurs de service numérique dans la mesure où la présente directive devrait s'appliquer à tous les fournisseurs de service numérique relevant de son champ d'application. En outre, la présente directive et les actes d'exécution adoptés en vertu de celle-ci devraient garantir un niveau élevé d'harmonisation pour les fournisseurs de service numérique en ce qui concerne les exigences en matière de sécurité et de notification. Cela devrait

permettre aux fournisseurs de service numérique de faire l'objet d'un traitement uniforme dans l'ensemble de l'Union, d'une manière proportionnée à la nature et à l'intensité du risque auquel ils pourraient être confrontés.

(58) La présente directive ne devrait pas empêcher les États membres d'imposer des exigences en matière de sécurité et de notification aux entités qui ne sont pas des fournisseurs de service numérique relevant du champ d'application de la présente directive, sans préjudice des obligations des États membres en vertu du droit de l'Union.

(59) Les autorités compétentes devraient veiller à préserver des canaux informels et dignes de confiance pour le partage d'informations. La divulgation d'informations sur les incidents signalés aux autorités compétentes devrait être le reflet d'un compromis entre l'intérêt, pour le public, d'être informé des menaces et les éventuelles conséquences néfastes, pour les opérateurs de services essentiels et les fournisseurs de service numérique signalant les incidents, en termes d'image comme sur le plan commercial. Lorsqu'ils mettent en œuvre les obligations de notification, les autorités compétentes et les CSIRT devraient être particulièrement attentifs à la nécessité de préserver la stricte confidentialité des informations sur les vulnérabilités des produits avant la publication des mises à jour de sécurité appropriées.

(60) Les fournisseurs de service numérique devraient être soumis à une surveillance a posteriori allégée et réactive, justifiée par la nature de leurs services et activités. L'autorité compétente concernée ne devrait dès lors intervenir que lorsqu'elle est informée, par exemple par le fournisseur de service numérique lui-même, par une autre autorité compétente, y compris une autorité compétente d'un autre État membre, ou par un utilisateur du service, d'éléments selon lesquels un fournisseur de service numérique ne satisfait pas aux exigences de la présente directive, notamment à la suite de la survenance d'un incident. L'autorité compétente devrait dès lors ne pas avoir d'obligation générale de surveiller les fournisseurs de service numérique.

(61) Les autorités compétentes devraient disposer des moyens nécessaires à l'exécution de leurs tâches, et notamment des pouvoirs leur permettant d'obtenir des informations suffisantes pour évaluer le niveau de sécurité des réseaux et des systèmes d'information.

(62) Un incident peut être le résultat d'activités criminelles, à propos desquelles la prévention, les enquêtes et les poursuites sont soutenues par la coordination et la coopération entre les opérateurs de services essentiels, les fournisseurs de service numérique, les autorités compétentes et les services répressifs. Lorsqu'il y a lieu de suspecter qu'un incident est lié à des activités criminelles graves au regard du droit de l'Union ou du droit national, les États membres devraient encourager les opérateurs de services essentiels et les fournisseurs de service numérique à signaler aux services répressifs compétents tout incident de ce type. Le cas échéant, il est souhaitable que la coordination entre les autorités compétentes et les services répressifs de différents États membres soit facilitée par le Centre européen de lutte contre la cybercriminalité (EC3) et l'ENISA.

(63) Dans de nombreux cas, des données à caractère personnel sont compromises à la suite d'incidents. Dans de telles circonstances, les autorités compétentes et les autorités chargées de la protection des données devraient coopérer et échanger des informations sur tous les aspects pertinents de la lutte contre toute atteinte aux données à caractère personnel à la suite d'incidents.

(64) La compétence dont relèvent les fournisseurs de service numérique devrait être attribuée à l'État membre dans lequel le fournisseur de service numérique concerné a son principal

établissement dans l'Union, ce qui correspond en principe à l'endroit où il a son siège social dans l'Union. L'établissement suppose l'exercice effectif et réel d'une activité au moyen d'une installation stable. La forme juridique retenue pour un tel établissement, qu'il s'agisse d'une succursale ou d'une filiale ayant la personnalité juridique, n'est pas déterminante à cet égard. Ce critère ne devrait pas dépendre du fait de savoir si les réseaux et systèmes d'information sont physiquement situés dans un lieu donné; la présence et l'utilisation de tels systèmes ne constituent pas en soi l'établissement principal et ne sont donc pas des critères permettant de déterminer l'établissement principal.

(65) Lorsqu'un fournisseur de service numérique, qui n'est pas établi dans l'Union, propose des services à l'intérieur de l'Union, il devrait désigner un représentant. Afin de déterminer si un tel fournisseur de service numérique propose des services dans l'Union, il convient d'examiner s'il apparaît qu'il envisage d'offrir des services à des personnes dans un ou plusieurs États membres. La seule accessibilité, dans l'Union, du site internet du fournisseur de service numérique ou d'un intermédiaire ou d'une adresse électronique et d'autres coordonnées ou encore l'utilisation d'une langue généralement utilisée dans le pays tiers où le fournisseur de service numérique est établi ne suffisent pas pour établir une telle intention. Cependant, des facteurs tels que l'utilisation d'une langue ou d'une monnaie généralement utilisées dans un ou plusieurs États membres avec la possibilité de commander des services dans cette autre langue ou la mention de clients ou d'utilisateurs qui se trouvent dans l'Union peuvent indiquer que le fournisseur de service numérique envisage d'offrir des services dans l'Union. Le représentant devrait agir pour le compte du fournisseur de service numérique et devrait pouvoir être contacté par les autorités compétentes ou les CSIRT. Le représentant devrait être expressément désigné par un mandat écrit du fournisseur de service numérique le chargeant d'agir en son nom pour remplir les obligations, y compris la notification des incidents, qui lui incombent en vertu de la présente directive.

(66) La normalisation des exigences en matière de sécurité est un processus guidé par le marché. Pour assurer l'application convergente des normes en matière de sécurité, les États membres devraient encourager le respect de normes précises ou la conformité à ces dernières afin de garantir un niveau élevé de sécurité des réseaux et des systèmes d'information au niveau de l'Union. L'ENISA devrait aider les États membres par la fourniture de conseils et de lignes directrices. À cette fin, il pourrait être utile d'élaborer des normes harmonisées, en se conformant au règlement (UE) n° 1025/2012 du Parlement européen et du Conseil ([8]).

(67) Les entités qui ne relèvent pas du champ d'application de la présente directive peuvent connaître des incidents ayant des conséquences importantes sur les services qu'elles fournissent. Lorsque ces entités estiment qu'il est dans l'intérêt public de notifier la survenance de tels incidents, elles devraient être en mesure de le faire à titre volontaire. Ces notifications devraient être traitées par l'autorité compétente ou le CSIRT lorsque leur traitement ne fait pas peser de charge disproportionnée ou inutile sur les États membres concernés.

(68) Afin d'assurer des conditions uniformes d'exécution de la présente directive, il convient de conférer des compétences d'exécution à la Commission pour fixer les modalités de procédure nécessaires au fonctionnement du groupe de coopération ainsi que les exigences en matière de sécurité et de notification applicables aux fournisseurs de service numérique. Ces compétences devraient être exercées en conformité avec le règlement (UE) n° 182/2011 du Parlement européen et du Conseil ([9]). Lorsqu'elle adopte des actes d'exécution liés aux modalités de

procédure nécessaires pour le fonctionnement du groupe de coopération, il y a lieu que la Commission tienne le plus grand compte de l'avis de l'ENISA.

(69) Lorsqu'elle adopte des actes d'exécution concernant les exigences en matière de sécurité à imposer aux fournisseurs de service numérique, la Commission devrait tenir le plus grand compte de l'avis de l'ENISA et consulter les parties intéressées. De plus, la Commission est encouragée à prendre en compte les exemples suivants: en ce qui concerne la sécurité des systèmes et des installations: sécurité physique et environnementale, sécurité de l'approvisionnement, contrôle de l'accès aux réseaux et aux systèmes d'information et intégrité desdits réseaux et systèmes d'information; en ce qui concerne la gestion des incidents: procédures de gestion des incidents, dispositif de détection des incidents, compte-rendu et notification d'incidents; en ce qui concerne la gestion de la continuité des activités: stratégie en matière de continuité du service et plans d'urgence, dispositif de rétablissement après sinistre; et en ce qui concerne le suivi, le contrôle et les tests: politiques de surveillance et d'enregistrement, exercices de mise en œuvre de plans d'urgence, tests des réseaux et des systèmes d'information, évaluations de la sécurité et contrôle du respect des exigences.

(70) Dans la mise en œuvre de la présente directive, la Commission devrait communiquer comme il se doit avec les comités sectoriels et organismes pertinents établis au niveau de l'Union dans les domaines couverts par la présente directive.

(71) La présente directive devrait être réexaminée périodiquement par la Commission, en consultation avec les parties prenantes intéressées, notamment en vue de déterminer s'il est nécessaire de la modifier pour tenir compte de l'évolution de la société, de la situation politique, des technologies ou de la situation des marchés.

(72) Le partage des informations sur les risques et incidents au sein du groupe de coopération et du réseau des CSIRT et le respect des exigences relatives à la notification des incidents aux autorités nationales compétentes ou aux CSIRT pourraient nécessiter le traitement de données à caractère personnel. Il convient que ce traitement respecte la directive 95/46/CE du Parlement européen et du Conseil ([10]) et le règlement (CE) n° 45/2001 du Parlement européen et du Conseil ([11]). Dans l'application de la présente directive, le règlement (CE) n° 1049/2001 du Parlement européen et du Conseil ([12]) devrait s'appliquer, le cas échéant.

(73) Le Contrôleur européen de la protection des données a été consulté conformément à l'article 28, paragraphe 2, du règlement (CE) n° 45/2001 et a rendu son avis le 14 juin 2013 ([13]).

(74) Étant donné que l'objectif de la présente directive, qui vise à atteindre un niveau élevé commun de sécurité des réseaux et des systèmes d'information dans l'Union, ne peut pas être atteint de manière suffisante par les États membres mais peut, en raison des effets de l'action, l'être mieux au niveau de l'Union, celle-ci peut prendre des mesures, conformément au principe de subsidiarité consacré à l'article 5 du traité sur l'Union européenne. Conformément au principe de proportionnalité tel qu'énoncé audit article, la présente directive n'excède pas ce qui est nécessaire pour atteindre cet objectif.

(75) La présente directive respecte les droits fondamentaux et observe les principes reconnus par la charte des droits fondamentaux de l'Union européenne et, en particulier, le droit au respect de la vie privée et des communications, le droit à la protection des données à caractère personnel, le droit à la liberté d'entreprise, le droit de propriété ainsi que le droit à un recours effectif et à un

procès équitable. La présente directive devrait être mise en œuvre conformément à ces droits et principes,

ONT ADOPTÉ LA PRÉSENTE DIRECTIVE:

CHAPITRE I
DISPOSITIONS GÉNÉRALES

Article premier

Objet et champ d'application

1. La présente directive établit des mesures visant à assurer un niveau élevé commun de sécurité des réseaux et des systèmes d'information dans l'Union afin d'améliorer le fonctionnement du marché intérieur.

2. À cette fin, la présente directive:

a) fixe des obligations à tous les États membres en ce qui concerne l'adoption d'une stratégie nationale en matière de sécurité des réseaux et des systèmes d'information;

b) institue un groupe de coopération afin de soutenir et faciliter la coopération stratégique et l'échange d'informations entre les États membres et de renforcer la confiance mutuelle;

c) institue un réseau des centres de réponse aux incidents de sécurité informatiques (ci-après dénommé «réseau des CSIRT») afin de contribuer au renforcement de la confiance entre les États membres et de promouvoir une coopération rapide et effective au niveau opérationnel;

d) établit des exigences en matière de sécurité et de notification pour les opérateurs de services essentiels et pour les fournisseurs de service numérique;

e) fixe des obligations aux États membres pour la désignation d'autorités nationales compétentes, de points de contact uniques et de CSIRT chargés de tâches liées à la sécurité des réseaux et des systèmes d'information.

3. Les exigences en matière de sécurité et de notification prévues par la présente directive ne s'appliquent pas aux entreprises soumises aux exigences énoncées aux articles 13 *bis* et 13 *ter* de la directive 2002/21/CE ni aux prestataires de services de confiance soumis aux exigences énoncées à l'article 19 du règlement (UE) n° 910/2014.

4. La présente directive est sans préjudice de la directive 2008/114/CE du Conseil ([14]) et des directives du Parlement européen et du Conseil 2011/93/UE ([15]) et 2013/40/UE ([16]).

5. Sans préjudice de l'article 346 du traité sur le fonctionnement de l'Union européenne, les informations considérées comme confidentielles en application de la réglementation nationale ou de l'Union, telle que les règles applicables au secret des affaires, ne peuvent faire l'objet d'un échange avec la Commission et d'autres autorités concernées que si cet échange est nécessaire à l'application de la présente directive. Les informations échangées se limitent au minimum nécessaire et sont proportionnées à l'objectif de cet échange. Cet échange d'informations préserve la confidentialité des informations concernées et protège la sécurité et les intérêts commerciaux des opérateurs de services essentiels et des fournisseurs de service numérique.

6. La présente directive est sans préjudice des mesures prises par les États membres pour préserver leurs fonctions étatiques essentielles, en particulier dans le but de préserver la sécurité nationale, notamment les mesures visant à protéger les informations dont la divulgation est considérée par les États membres comme contraire aux intérêts essentiels de leur sécurité, et de maintenir l'ordre public, en particulier pour permettre la détection des infractions pénales ainsi que les enquêtes et les poursuites en la matière.

7. Lorsqu'un acte juridique sectoriel de l'Union exige des opérateurs de services essentiels ou des fournisseurs de service numérique qu'ils assurent la sécurité de leurs réseaux et systèmes d'information ou qu'ils procèdent à la notification des incidents, à condition que les exigences en question aient un effet au moins équivalent à celui des obligations prévues par la présente directive, les dispositions de cet acte juridique sectoriel de l'Union s'appliquent.

Article 2

Traitement des données à caractère personnel

1. Le traitement de données à caractère personnel au titre de la présente directive est effectué conformément à la directive 95/46/CE.

2. Le traitement de données à caractère personnel par les institutions et organes de l'Union au titre de la présente directive est effectué conformément au règlement (CE) n° 45/2001.

Article 3

Harmonisation minimale

Sans préjudice de l'article 16, paragraphe 10, et des obligations qui leur incombent en vertu du droit de l'Union, les États membres peuvent adopter ou maintenir des dispositions en vue de parvenir à un niveau de sécurité plus élevé des réseaux et des systèmes d'information.

Article 4

Définitions

Aux fins de la présente directive, on entend par:

1) **«réseau et système d'information»**:

a) un réseau de communications électroniques au sens de l'article 2, point a), de la directive 2002/21/CE;

b) tout dispositif ou tout ensemble de dispositifs interconnectés ou apparentés, dont un ou plusieurs éléments assurent, en exécution d'un programme, un traitement automatisé de données numériques; ou

c) les données numériques stockées, traitées, récupérées ou transmises par les éléments visés aux points a) et b) en vue de leur fonctionnement, utilisation, protection et maintenance;

2) **«sécurité des réseaux et des systèmes d'information»**: la capacité des réseaux et des systèmes d'information de résister, à un niveau de confiance donné, à des actions qui compromettent la disponibilité, l'authenticité, l'intégrité ou la confidentialité de données stockées, transmises ou faisant l'objet d'un traitement, et des services connexes que ces réseaux et systèmes d'information offrent ou rendent accessibles;

3) **«stratégie nationale en matière de sécurité des réseaux et des systèmes d'information»**: un cadre prévoyant des objectifs et priorités stratégiques en matière de sécurité des réseaux et des systèmes d'information au niveau national;

4) **«opérateur de services essentiels»**: une entité publique ou privée dont le type figure à l'annexe II et qui répond aux critères énoncés à l'article 5, paragraphe 2;

5) **«service numérique»**: un service au sens de l'article 1er, paragraphe 1, point b), de la directive (UE) 2015/1535 du Parlement européen et du Conseil ([17]) dont le type figure dans la liste de l'annexe III;

6) **«fournisseur de service numérique»**: une personne morale qui fournit un service numérique;

7) **«incident»**: tout événement ayant un impact négatif réel sur la sécurité des réseaux et des systèmes d'information;

8) **«gestion d'incident»**: toutes les procédures utiles à la détection, à l'analyse et au confinement d'un incident et toutes les procédures utiles à l'intervention en cas d'incident;

9) **«risque»**: toute circonstance ou tout événement raisonnablement identifiable ayant un impact négatif potentiel sur la sécurité des réseaux et des systèmes d'information;

10) **«représentant»**: une personne physique ou morale établie dans l'Union qui est expressément désignée pour agir pour le compte d'un fournisseur de service numérique non établi dans l'Union, qui peut être contactée par une autorité nationale compétente ou un CSIRT à la place du fournisseur de service numérique concernant les obligations incombant audit fournisseur de service numérique en vertu de la présente directive;

11) **«norme»**: une norme au sens de l'article 2, point 1), du règlement (UE) no 1025/2012;

12) **«spécification»**: une spécification technique au sens de l'article 2, point 4), du règlement (UE) no 1025/2012;

13) **«point d'échange internet» (IXP)**: une structure de réseau qui permet l'interconnexion de plus de deux systèmes autonomes indépendants, essentiellement aux fins de faciliter l'échange de trafic internet; un IXP n'assure l'interconnexion que pour des systèmes autonomes; un IXP n'exige pas que le trafic internet passant entre une paire quelconque de systèmes autonomes participants transite par un système autonome tiers, pas plus qu'il ne modifie ou n'altère par ailleurs un tel trafic;

14) **«système de noms de domaine» (DNS)**: un système hiérarchique et distribué d'affectation de noms dans un réseau qui résout les questions liées aux noms de domaines;

15) **«fournisseur de services DNS»**: une entité qui fournit des services DNS sur l'internet;

16) **«registre de noms de domaine de haut niveau»**: une entité qui administre et gère l'enregistrement de noms de domaine internet dans un domaine de haut niveau donné;

17) **«place de marché en ligne»**: un service numérique qui permet à des consommateurs et/ou à des professionnels au sens de l'article 4, paragraphe 1, point a) ou point b) respectivement, de la directive 2013/11/UE du Parlement européen et du Conseil ([18]) de conclure des contrats de vente ou de service en ligne avec des professionnels soit sur le site internet de la place de marché en ligne, soit sur le site internet d'un professionnel qui utilise les services informatiques fournis par la place de marché en ligne;

18) **«moteur de recherche en ligne»**: un service numérique qui permet aux utilisateurs d'effectuer des recherches sur, en principe, tous les sites internet ou sur les sites internet dans une langue donnée, sur la base d'une requête lancée sur n'importe quel sujet sous la forme d'un mot clé, d'une phrase ou d'une autre entrée, et qui renvoie des liens à partir desquels il est possible de trouver des informations en rapport avec le contenu demandé;

19) **«service d'informatique en nuage»**: un service numérique qui permet l'accès à un ensemble modulable et variable de ressources informatiques pouvant être partagées.

Article 5

Identification des opérateurs de services essentiels

1. Au plus tard le 9 novembre 2018, pour chaque secteur et sous-secteur visé à l'annexe II, les États membres identifient les opérateurs de services essentiels ayant un établissement sur leur territoire.

2. Les critères d'identification des opérateurs de services essentiels visés à l'article 4, point 4), sont les suivants:

a) une entité fournit un service qui est essentiel au maintien d'activités sociétales et/ou économiques critiques;

b) la fourniture de ce service est tributaire des réseaux et des systèmes d'information; et

c) un incident aurait un effet disruptif important sur la fourniture dudit service.

3. Aux fins du paragraphe 1, chaque État membre établit une liste des services visés au paragraphe 2, point a).

4. Aux fins du paragraphe 1, lorsqu'une entité fournit un service visé au paragraphe 2, point a), dans deux États membres ou plus, les États membres en question se consultent mutuellement. La consultation intervient avant que l'identification ne fasse l'objet d'une décision.

5. À intervalles réguliers et au moins tous les deux ans à compter du 9 mai 2018, les États membres procèdent au réexamen et, au besoin, à la mise à jour de la liste des opérateurs de services essentiels identifiés.

6. Le rôle du groupe de coopération consiste, conformément aux tâches visées à l'article 11, à aider les États membres à suivre une approche cohérente dans le processus d'identification des opérateurs de services essentiels.

7. Aux fins du réexamen visé à l'article 23 et au plus tard le 9 novembre 2018, puis tous les deux ans, les États membres communiquent à la Commission les informations qui lui sont nécessaires pour évaluer la mise en œuvre de la présente directive, en particulier la cohérence des approches adoptées par les États membres pour l'identification des opérateurs de services essentiels. Ces informations comprennent au moins:

a) les mesures nationales permettant l'identification des opérateurs de services essentiels;

b) la liste des services visée au paragraphe 3;

c) le nombre d'opérateurs de services essentiels identifiés pour chaque secteur visé à l'annexe II et une indication de leur importance pour ce secteur;

d) les seuils, pour autant qu'ils existent, permettant de déterminer le niveau de l'offre pertinent en fonction du nombre d'utilisateurs tributaires de ce service visé à l'article 6, paragraphe 1, point a), ou de l'importance de cet opérateur de services essentiels particulier visée à l'article 6, paragraphe 1, point f).

Afin de contribuer à la transmission d'informations comparables, la Commission peut, en tenant le plus grand compte de l'avis de l'ENISA, adopter des lignes directrices techniques appropriées concernant les paramètres applicables aux informations visées dans le présent paragraphe.

Article 6

Effet disruptif important

1. Lorsque les États membres déterminent l'importance d'un effet disruptif visée à l'article 5, paragraphe 2, point c), ils prennent en compte au moins les facteurs transsectoriels suivants:

a) le nombre d'utilisateurs tributaires du service fourni par l'entité concernée;

b) la dépendance des autres secteurs visés à l'annexe II à l'égard du service fourni par cette entité;

c) les conséquences que des incidents pourraient avoir, en termes de degré et de durée, sur les fonctions économiques ou sociétales ou sur la sûreté publique;

d) la part de marché de cette entité;

e) la portée géographique eu égard à la zone susceptible d'être touchée par un incident;

f) l'importance que revêt l'entité pour garantir un niveau de service suffisant, compte tenu de la disponibilité de solutions de rechange pour la fourniture de ce service.

2. Afin de déterminer si un incident est susceptible d'avoir un effet disruptif important, les États membres prennent aussi en compte, le cas échéant, des facteurs sectoriels.

CHAPITRE II

CADRES NATIONAUX SUR LA SÉCURITÉ DES RÉSEAUX ET DES SYSTÈMES D'INFORMATION

Article 7

Stratégie nationale en matière de sécurité des réseaux et des systèmes d'information

1. Chaque État membre adopte une stratégie nationale en matière de sécurité des réseaux et des systèmes d'information qui définit les objectifs stratégiques et les mesures politiques et réglementaires appropriées en vue de parvenir à un niveau élevé de sécurité des réseaux et des systèmes d'information et de le maintenir et de couvrir au moins les secteurs visés à l'annexe II et les services visés à l'annexe III. La stratégie nationale en matière de sécurité des réseaux et des systèmes d'information porte, en particulier, sur les points suivants:

a) les objectifs et les priorités de la stratégie nationale en matière de sécurité des réseaux et des systèmes d'information;

b) un cadre de gouvernance permettant d'atteindre les objectifs et les priorités de la stratégie nationale en matière de sécurité des réseaux et des systèmes d'information, prévoyant

notamment les rôles et les responsabilités des organismes publics et des autres acteurs pertinents;

c) l'inventaire des mesures en matière de préparation, d'intervention et de récupération, y compris la coopération entre les secteurs public et privé;

d) un aperçu des programmes d'éducation, de sensibilisation et de formation en rapport avec la stratégie nationale en matière de sécurité des réseaux et des systèmes d'information;

e) un aperçu des plans de recherche et de développement en rapport avec la stratégie nationale en matière de sécurité des réseaux et des systèmes d'information;

f) un plan d'évaluation des risques permettant d'identifier les risques;

g) une liste des différents acteurs concernés par la mise en œuvre de la stratégie nationale en matière de sécurité des réseaux et des systèmes d'information.

2. Les États membres peuvent demander à l'ENISA de leur prêter assistance dans l'élaboration de leur stratégie nationale en matière de sécurité des réseaux et des systèmes d'information.

3. Les États membres communiquent leur stratégie nationale en matière de sécurité des réseaux et des systèmes d'information à la Commission dans un délai de trois mois suivant son adoption. Dans ce cadre, les États membres peuvent exclure des éléments de la stratégie se rapportant à la sécurité nationale.

Article 8

Autorités nationales compétentes et point de contact unique

1. Chaque État membre désigne une ou plusieurs autorités nationales compétentes en matière de sécurité des réseaux et des systèmes d'information (ci-après dénommées «autorités compétentes»), couvrant au moins les secteurs visés à l'annexe II et les services visés à l'annexe III. Les États membres peuvent attribuer cette mission à une ou des autorités existantes.

2. Les autorités compétentes contrôlent l'application de la présente directive au niveau national.

3. Chaque État membre désigne un point de contact national unique en matière de sécurité des réseaux et des systèmes d'information (ci-après dénommé «point de contact unique»). Les États membres peuvent attribuer cette mission à une autorité existante. Lorsqu'un État membre désigne une seule autorité compétente, cette dernière fait aussi fonction de point de contact unique.

4. Le point de contact unique exerce une fonction de liaison pour assurer une coopération transfrontalière entre les autorités des États membres, ainsi qu'avec les autorités concernées des autres États membres, le groupe de coopération visé à l'article 11 et le réseau des CSIRT visé à l'article 12.

5. Les États membres veillent à ce que les autorités compétentes et les points de contact uniques disposent de ressources suffisantes pour pouvoir s'acquitter de leurs tâches de manière effective et efficace et atteindre ainsi les objectifs de la présente directive. Les États membres font en sorte que les représentants désignés pour siéger au sein du groupe de coopération puissent coopérer de manière effective, efficace et sûre.

6. En fonction des besoins et conformément au droit national, les autorités compétentes et le point de contact unique consultent les services répressifs nationaux compétents et les autorités nationales chargées de la protection des données et coopèrent avec eux.

7. Chaque État membre notifie sans tarder à la Commission la désignation de l'autorité compétente et du point de contact unique, les tâches qui leur sont confiées et toute modification ultérieure dans ce cadre. Chaque État membre rend publique la désignation de l'autorité compétente et du point de contact unique. La Commission publie la liste des points de contact uniques désignés.

Article 9

Centres de réponse aux incidents de sécurité informatique (CSIRT)

1. Chaque État membre désigne un ou plusieurs CSIRT, se conformant aux exigences énumérées à l'annexe I, point 1), couvrant au moins les secteurs visés à l'annexe II et les services visés à l'annexe III, chargés de la gestion des incidents et des risques selon un processus bien défini. Un CSIRT peut être établi au sein d'une autorité compétente.

2. Les États membres veillent à ce que les CSIRT disposent de ressources suffisantes pour pouvoir s'acquitter efficacement de leurs tâches énumérées à l'annexe I, point 2).

Les États membres veillent à ce que leurs CSIRT coopèrent de manière effective, efficace et sécurisée au sein du réseau des CSIRT visé à l'article 12.

3. Les États membres font en sorte que leurs CSIRT aient accès à une infrastructure d'information et de communication adaptée, sécurisée et résiliente au niveau national.

4. Les États membres informent la Commission des missions de leurs CSIRT ainsi que des principaux éléments de leurs processus de gestion des incidents.

5. Les États membres peuvent solliciter l'assistance de l'ENISA pour la mise en place des CSIRT nationaux.

Article 10

Coopération au niveau national

1. Lorsqu'ils sont distincts, l'autorité compétente, le point de contact unique et le CSIRT d'un même État membre coopèrent aux fins du respect des obligations énoncées dans la présente directive.

2. Les États membres veillent à ce que soit les autorités compétentes, soit les CSIRT reçoivent les notifications d'incidents transmises en application de la présente directive. Lorsqu'un État membre décide que les CSIRT ne reçoivent pas de notifications, ils se voient accorder, dans la mesure nécessaire à l'accomplissement de leurs tâches, un accès aux données relatives aux incidents notifiés par les opérateurs de services essentiels au titre de l'article 14, paragraphes 3 et 5, ou par les fournisseurs de service numérique au titre de l'article 16, paragraphes 3 et 6.

3. Les États membres veillent à ce que les autorités compétentes ou les CSIRT informent les points de contact uniques des notifications d'incidents transmises en application de la présente directive.

Au plus tard le 9 août 2018, puis tous les ans, le point de contact unique transmet au groupe de coopération un rapport de synthèse sur les notifications reçues, y compris le nombre de notifications et la nature des incidents notifiés, ainsi que sur les mesures prises conformément à l'article 14, paragraphes 3 et 5, et à l'article 16, paragraphes 3 et 6.

CHAPITRE III

COOPÉRATION

Article 11

Groupe de coopération

1. Un groupe de coopération est institué aux fins de soutenir et de faciliter la coopération stratégique et l'échange d'informations entre les États membres et de renforcer la confiance, et de parvenir à un niveau élevé commun de sécurité des réseaux et des systèmes d'information dans l'Union.

Le groupe de coopération exécute ses tâches en s'appuyant sur les programmes de travail bisannuels visés au paragraphe 3, deuxième alinéa.

2. Le groupe de coopération est composé de représentants des États membres, de la Commission et de l'ENISA.

Si besoin est, le groupe de coopération peut inviter des représentants des acteurs concernés à participer à ses travaux.

Le secrétariat est assuré par la Commission.

3. Le groupe de coopération est chargé des tâches suivantes:

a) fournir des orientations stratégiques pour les activités du réseau des CSIRT institué en vertu de l'article 12;

b) échanger les bonnes pratiques concernant l'échange d'informations sur les notifications d'incidents visé à l'article 14, paragraphes 3 et 5, et à l'article 16, paragraphes 3 et 6;

c) échanger les bonnes pratiques entre les États membres et, en coopération avec l'ENISA, aider les États membres à renforcer leurs capacités en matière de sécurité des réseaux et des systèmes d'information;

d) discuter des capacités et de l'état de préparation des États membres et, à titre volontaire, évaluer les stratégies nationales en matière de sécurité des réseaux et des systèmes d'information et l'efficacité des CSIRT, et identifier les bonnes pratiques;

e) échanger des informations et les bonnes pratiques en matière de sensibilisation et de formation;

f) échanger des informations et les bonnes pratiques en matière de recherche et de développement dans le domaine de la sécurité des réseaux et des systèmes d'information;

g) le cas échéant, procéder à des échanges d'expériences sur des questions relatives à la sécurité des réseaux et des systèmes d'information avec les institutions, organes ou organismes de l'Union concernés;

h) discuter des normes et des spécifications visées à l'article 19 avec les représentants des organismes de normalisation européens concernés;

i) recueillir des informations sur les bonnes pratiques en matière de risques et d'incidents;

j) examiner chaque année les rapports de synthèse visés à l'article 10, paragraphe 3, deuxième alinéa;

k) discuter du travail accompli en ce qui concerne les exercices relatifs à la sécurité des réseaux et des systèmes d'information, les programmes d'éducation et la formation, y compris le travail réalisé par l'ENISA;

l) avec l'assistance de l'ENISA, échanger les bonnes pratiques concernant l'identification, par les États membres, des opérateurs de services essentiels, y compris au regard des dépendances transfrontalières, en matière de risques et d'incidents;

m) discuter des modalités de signalement des notifications d'incidents visées aux articles 14 et 16.

Au plus tard le 9 février 2018, puis tous les deux ans, le groupe de coopération établit un programme de travail prévoyant les actions à entreprendre pour mettre en œuvre les objectifs et les tâches et qui est cohérent avec les objectifs de la présente directive.

4. Aux fins du réexamen visé à l'article 23 et au plus tard le 9 août 2018, puis tous les ans et demi, le groupe de coopération établit un rapport évaluant l'expérience acquise à la suite de la coopération stratégique visée au présent article.

5. La Commission adopte des actes d'exécution fixant les modalités de procédure nécessaires au fonctionnement du groupe de coopération. Ces actes d'exécution sont adoptés en conformité avec la procédure d'examen visée à l'article 22, paragraphe 2.

Aux fins du premier alinéa, la Commission présente au comité visé à l'article 22, paragraphe 1, le premier projet d'acte d'exécution le 9 février 2017 au plus tard.

Article 12

Réseau des CSIRT

1. Afin de contribuer au renforcement de la confiance entre les États membres et de promouvoir une coopération opérationnelle rapide et effective, un réseau des CSIRT nationaux est établi.

2. Le réseau des CSIRT est composé de représentants des CSIRT des États membres et du CERT-UE. La Commission participe au réseau des CSIRT en qualité d'observateur. L'ENISA assure le secrétariat et soutient activement la coopération entre les CSIRT.

3. Le réseau des CSIRT est chargé des tâches suivantes:

a) échanger des informations sur les services, les opérations et les capacités de coopération des CSIRT;

b) à la demande du représentant d'un CSIRT d'un État membre susceptible d'être touché par un incident, échanger des informations non sensibles d'un point de vue commercial en rapport avec l'incident en question et les risques correspondants et en débattre; toutefois, un CSIRT d'un État membre peut refuser de contribuer à ce débat s'il existe un risque de porter atteinte à l'enquête sur l'incident;

c) échanger et mettre à disposition, à titre volontaire, des informations non confidentielles sur les différents incidents;

d) à la demande du représentant d'un CSIRT d'un État membre, discuter et, si possible, identifier une réponse coordonnée à un incident identifié qui relève de la juridiction de ce même État membre;

e) aider les États membres à faire face à des incidents transfrontaliers sur la base d'une assistance mutuelle volontaire;

f) débattre, étudier et identifier d'autres formes de coopération opérationnelle, notamment en rapport avec:

i) les catégories de risques et d'incidents;

ii) les alertes précoces;

iii) l'assistance mutuelle;

iv) les principes et modalités d'une coordination lorsque les États membres réagissent à des risques et incidents transfrontaliers;

g) informer le groupe de coopération des activités du réseau et des autres formes de coopération opérationnelle débattues en application du point f) et demander des orientations à cet égard;

h) étudier les enseignements tirés des exercices relatifs à la sécurité des réseaux et des systèmes d'information, y compris de ceux organisés par l'ENISA;

i) à la demande d'un CSIRT donné, étudier les capacités et l'état de préparation dudit CSIRT;

j) publier des lignes directrices afin de faciliter la convergence des pratiques opérationnelles en ce qui concerne l'application des dispositions du présent article relatives à la coopération opérationnelle.

4. Aux fins du réexamen visé à l'article 23 et au plus tard le 9 août 2018, puis tous les ans et demi, le réseau des CSIRT établit un rapport évaluant l'expérience acquise à la suite de la coopération opérationnelle visée au présent article, comprenant des conclusions et des recommandations. Ce rapport est aussi transmis au groupe de coopération.

5. Le réseau des CSIRT établit son propre règlement intérieur.

Article 13

Coopération internationale

L'Union peut, conformément à l'article 218 du traité sur le fonctionnement de l'Union européenne, conclure, avec des pays tiers ou des organisations internationales, des accords internationaux qui permettent et organisent leur participation à certaines activités du groupe de coopération. Ces accords tiennent compte de la nécessité d'assurer un niveau suffisant de protection des données.

CHAPITRE IV

SÉCURITÉ DES RÉSEAUX ET DES SYSTÈMES D'INFORMATION DES OPÉRATEURS DE SERVICES ESSENTIELS

Article 14

Exigences de sécurité et notification d'incidents

1. Les États membres veillent à ce que les opérateurs de services essentiels prennent les mesures techniques et organisationnelles nécessaires et proportionnées pour gérer les risques qui menacent la sécurité des réseaux et des systèmes d'information qu'ils utilisent dans le cadre de leurs activités. Ces mesures garantissent, pour les réseaux et les systèmes d'information, un niveau de sécurité adapté au risque existant, compte tenu de l'état des connaissances.

2. Les États membres veillent à ce que les opérateurs de services essentiels prennent les mesures appropriées en vue de prévenir les incidents qui compromettent la sécurité des réseaux et des

systèmes d'information utilisés pour la fourniture de ces services essentiels ou d'en limiter l'impact, en vue d'assurer la continuité de ces services.

3. Les États membres veillent à ce que les opérateurs de services essentiels notifient à l'autorité compétente ou au CSIRT, sans retard injustifié, les incidents qui ont un impact significatif sur la continuité des services essentiels qu'ils fournissent. Les notifications contiennent des informations permettant à l'autorité compétente ou au CSIRT de déterminer si l'incident a un impact au niveau transfrontalier. Cette notification n'accroît pas la responsabilité de la partie qui en est à l'origine.

4. Afin de déterminer l'ampleur de l'impact d'un incident, il est, en particulier, tenu compte des paramètres suivants:

a) le nombre d'utilisateurs touchés par la perturbation du service essentiel;

b) la durée de l'incident;

c) la portée géographique eu égard à la zone touchée par l'incident.

5. Sur la base des informations fournies dans la notification de l'opérateur de services essentiels, l'autorité compétente ou le CSIRT signale aux autres États membres touchés si l'incident a un impact significatif sur la continuité des services essentiels dans ces États membres. Ce faisant, l'autorité compétente ou le CSIRT doit, dans le respect du droit de l'Union ou de la législation nationale conforme au droit de l'Union, préserver la sécurité et les intérêts commerciaux de l'opérateur de services essentiels ainsi que la confidentialité des informations communiquées dans sa notification.

Lorsque les circonstances le permettent, l'autorité compétente ou le CSIRT fournit à l'opérateur de services essentiels qui est à l'origine de la notification des informations utiles au suivi de sa notification, par exemple celles qui pourraient contribuer à une gestion efficace de l'incident.

À la demande de l'autorité compétente ou du CSIRT, le point de contact unique transmet les notifications visées au premier alinéa aux points de contact uniques des autres États membres touchés.

6. Après avoir consulté l'opérateur de services essentiels qui est à l'origine de la notification, l'autorité compétente ou le CSIRT peut informer le public concernant des incidents particuliers, lorsque la sensibilisation du public est nécessaire pour prévenir un incident ou gérer un incident en cours.

7. Les autorités compétentes, agissant de concert au sein du groupe de coopération, peuvent élaborer et adopter des lignes directrices relatives aux circonstances dans lesquelles les opérateurs de services essentiels sont tenus de notifier les incidents, y compris en ce qui concerne les paramètres permettant de déterminer l'ampleur de l'impact d'un incident au sens du paragraphe 4.

Article 15

Mise en œuvre et exécution

1. Les États membres veillent à ce que les autorités compétentes disposent des pouvoirs et des moyens nécessaires pour évaluer le respect, par les opérateurs de services essentiels, des obligations qui leur incombent en vertu de l'article 14, ainsi que les effets de ce respect sur la sécurité des réseaux et des systèmes d'information.

2. Les États membres veillent à ce que les autorités compétentes disposent des pouvoirs et des moyens leur permettant d'exiger des opérateurs de services essentiels qu'ils fournissent:

a) les informations nécessaires pour évaluer la sécurité de leurs réseaux et systèmes d'information, y compris les documents relatifs à leurs politiques de sécurité;

b) des éléments prouvant la mise en œuvre effective des politiques de sécurité, tels que les résultats d'un audit de sécurité exécuté par l'autorité compétente ou un auditeur qualifié et, dans ce dernier cas, qu'ils en mettent les résultats, y compris les éléments probants, à la disposition de l'autorité compétente.

Au moment de formuler une telle demande d'informations et de preuves, l'autorité compétente mentionne la finalité de la demande et précise quelles sont les informations exigées.

3. Après évaluation des informations ou des résultats des audits de sécurité visés au paragraphe 2, l'autorité compétente peut donner des instructions contraignantes aux opérateurs de services essentiels pour remédier aux défaillances identifiées.

4. Pour traiter des incidents donnant lieu à des violations des données à caractère personnel, l'autorité compétente coopère étroitement avec les autorités chargées de la protection des données.

CHAPITRE V

SÉCURITÉ DES RÉSEAUX ET DES SYSTÈMES D'INFORMATION DES FOURNISSEURS DE SERVICE NUMÉRIQUE

Article 16

Exigences de sécurité et notification d'incidents

1. Les États membres veillent à ce que les fournisseurs de service numérique identifient les risques qui menacent la sécurité des réseaux et des systèmes d'information qu'ils utilisent pour offrir, dans l'Union, les services visés à l'annexe III, et prennent les mesures techniques et organisationnelles nécessaires et proportionnées pour les gérer. Ces mesures garantissent, compte tenu de l'état des connaissances, un niveau de sécurité des réseaux et des systèmes d'information adapté au risque existant et prennent en considération les éléments suivants:

a) la sécurité des systèmes et des installations;

b) la gestion des incidents;

c) la gestion de la continuité des activités;

d) le suivi, l'audit et le contrôle;

e) le respect des normes internationales.

2. Les États membres veillent à ce que les fournisseurs de service numérique prennent des mesures pour éviter les incidents portant atteinte à la sécurité de leurs réseaux et systèmes d'information, et réduire au minimum l'impact de ces incidents sur les services visés à l'annexe III qui sont offerts dans l'Union, de manière à garantir la continuité de ces services.

3. Les États membres veillent à ce que les fournisseurs de service numérique notifient à l'autorité compétente ou au CSIRT, sans retard injustifié, tout incident ayant un impact significatif sur la fourniture d'un service visé à l'annexe III qu'ils offrent dans l'Union. Les notifications contiennent des informations permettant à l'autorité compétente ou au CSIRT d'évaluer l'ampleur de l'éventuel

impact au niveau transfrontalier. Cette notification n'accroît pas la responsabilité de la partie qui en est à l'origine.

4. Afin de déterminer l'importance de l'impact d'un incident, il convient de tenir compte, en particulier, des paramètres qui suivent:

a) le nombre d'utilisateurs touchés par l'incident, en particulier ceux qui recourent au service pour la fourniture de leurs propres services;

b) la durée de l'incident;

c) la portée géographique eu égard à la zone touchée par l'incident;

d) la gravité de la perturbation du fonctionnement du service;

e) l'ampleur de l'impact sur les fonctions économiques et sociétales.

L'obligation de notifier un incident ne s'applique que lorsque le fournisseur de service numérique a accès aux informations nécessaires pour évaluer l'impact de l'incident eu égard aux paramètres visés au premier alinéa.

5. Lorsqu'un opérateur de services essentiels s'appuie sur un tiers fournisseur de service numérique pour la prestation d'un service essentiel au maintien de fonctions sociétales et économiques critiques, tout impact significatif sur la continuité des services essentiels en raison d'un incident touchant le fournisseur de service numérique est notifié par ledit opérateur.

6. Lorsque c'est approprié, et notamment si l'incident visé au paragraphe 3 concerne deux États membres ou plus, l'autorité compétente ou le CSIRT informe les autres États membres touchés. Ce faisant, les autorités compétentes, les CSIRT et les points de contact uniques doivent, dans le respect du droit de l'Union ou de la législation nationale conforme au droit de l'Union, préserver la sécurité et les intérêts commerciaux du fournisseur de service numérique ainsi que la confidentialité des informations communiquées.

7. Après avoir consulté le fournisseur de service numérique concerné, l'autorité compétente ou le CSIRT et, lorsque c'est approprié, les autorités ou les CSIRT des autres États membres concernés peuvent informer le public d'incidents particuliers ou imposer au fournisseur de service numérique de le faire, dans le cas où la sensibilisation du public est nécessaire pour prévenir un incident ou pour gérer un incident en cours, ou lorsque la divulgation de l'incident est dans l'intérêt public à d'autres égards.

8. La Commission adopte des actes d'exécution afin de compléter les éléments visés au paragraphe 1 et les paramètres énumérés au paragraphe 4 du présent article. Ces actes d'exécution sont adoptés en conformité avec la procédure d'examen visée à l'article 22, paragraphe 2, au plus tard le 9 août 2017.

9. La Commission peut adopter des actes d'exécution fixant les formats et les procédures à appliquer pour respecter les exigences en matière de notification. Ces actes d'exécution sont adoptés en conformité avec la procédure d'examen visée à l'article 22, paragraphe 2.

10. Sans préjudice de l'article 1er, paragraphe 6, les États membres n'imposent pas aux fournisseurs de service numérique d'autres exigences liées à la sécurité ou aux notifications.

11. Le chapitre V ne s'applique pas aux microentreprises et petites entreprises telles qu'elles sont définies dans la recommandation 2003/361/CE de la Commission (19).

Article 17

Mise en œuvre et exécution

1. Les États membres veillent à ce que les autorités compétentes prennent des mesures, au besoin, dans le cadre de mesures de contrôle a posteriori, lorsque, selon les éléments communiqués, un fournisseur de service numérique ne satisfait pas aux exigences énoncées à l'article 16. Ces éléments peuvent être communiqués par une autorité compétente d'un autre État membre dans lequel le service est fourni.

2. Aux fins du paragraphe 1, les autorités compétentes disposent des pouvoirs et des moyens nécessaires pour imposer aux fournisseurs de service numérique:

a) de communiquer les informations nécessaires pour évaluer la sécurité de leurs réseaux et systèmes d'information, y compris les documents relatifs à leurs politiques de sécurité;

b) de corriger tout manquement aux obligations fixées à l'article 16.

3. Si un fournisseur de service numérique a son établissement principal ou un représentant dans un État membre alors que ses réseaux et systèmes d'information sont situés dans un ou plusieurs autres États membres, l'autorité compétente de l'État membre de l'établissement principal ou du représentant et les autorités compétentes de ces autres États membres coopèrent et se prêtent mutuellement assistance si nécessaire. Cette assistance et cette coopération peuvent porter sur les échanges d'informations entre les autorités compétentes concernées et sur les demandes de prise de mesures de contrôle visées au paragraphe 2.

Article 18

Compétence et territorialité

1. Aux fins de la présente directive, un fournisseur de service numérique est considéré comme relevant de la compétence de l'État membre dans lequel il a son établissement principal. Un fournisseur de service numérique est réputé avoir son établissement principal dans un État membre lorsque son siège social se trouve dans cet État membre.

2. Un fournisseur de service numérique qui n'est pas établi dans l'Union mais fournit des services visés à l'annexe III à l'intérieur de l'Union désigne un représentant dans l'Union. Le représentant est établi dans l'un des États membres dans lesquels les services sont fournis. Le fournisseur de service numérique est considéré comme relevant de la compétence de l'État membre dans lequel le représentant est établi.

3. La désignation d'un représentant par le fournisseur de service numérique est sans préjudice d'actions en justice qui pourraient être intentées contre le fournisseur de service numérique lui-même.

CHAPITRE VI
NORMALISATION ET NOTIFICATION VOLONTAIRE

Article 19

Normalisation

1. Afin de favoriser la convergence de la mise en œuvre de l'article 14, paragraphes 1 et 2, et de l'article 16, paragraphes 1 et 2, les États membres encouragent, sans imposer l'utilisation d'un type particulier de technologies ni créer de discrimination en faveur d'un tel type particulier de technologies, le recours à des normes et des spécifications européennes ou internationalement reconnues pour la sécurité des réseaux et des systèmes d'information.

2. L'ENISA, en collaboration avec les États membres, formule des avis et des lignes directrices relatives aux domaines techniques qui doivent être pris en considération en liaison avec le paragraphe 1 et relatives aux normes existantes, y compris les normes nationales des États membres, qui permettraient de couvrir ces domaines.

Article 20

Notification volontaire

1. Sans préjudice de l'article 3, les entités qui n'ont pas été identifiées en tant qu'opérateurs de services essentiels et qui ne sont pas des fournisseurs de service numérique peuvent notifier, à titre volontaire, les incidents ayant un impact significatif sur la continuité des services qu'elles fournissent.

2. Lorsqu'ils traitent des notifications, les États membres agissent conformément à la procédure énoncée à l'article 14. Les États membres peuvent traiter les notifications obligatoires en leur donnant la priorité par rapport aux notifications volontaires. Les notifications volontaires ne sont traitées que lorsque leur traitement ne fait pas peser de charge disproportionnée ou inutile sur les États membres concernés.

Une notification volontaire n'a pas pour effet d'imposer à l'entité qui est à l'origine de la notification des obligations auxquelles elle n'aurait pas été soumise si elle n'avait pas procédé à ladite notification.

CHAPITRE VII
DISPOSITIONS FINALES

Article 21

Sanctions

Les États membres fixent des règles relatives aux sanctions applicables en cas d'infraction aux dispositions nationales adoptées en vertu de la présente directive et prennent toutes les mesures nécessaires pour que ces règles soient appliquées. Les sanctions prévues sont effectives, proportionnées et dissuasives. Les États membres notifient ces règles et ces mesures à la Commission au plus tard le 9 mai 2018 et lui notifient sans retard toute modification ultérieure les concernant.

Article 22

Comité

1. La Commission est assistée par le comité de la sécurité des réseaux et des systèmes d'information. Ledit comité est un comité au sens du règlement (UE) n° 182/2011.

2. Lorsqu'il est fait référence au présent paragraphe, l'article 5 du règlement (UE) n° 182/2011 s'applique.

Article 23

Réexamen

1. Au plus tard le 9 mai 2019, la Commission présente au Parlement européen et au Conseil un rapport évaluant la cohérence de l'approche adoptée par les États membres pour identifier les opérateurs de services essentiels.

2. La Commission réexamine périodiquement le fonctionnement de la présente directive et en rend compte au Parlement européen et au Conseil. À cette fin et en vue de faire progresser la coopération stratégique et opérationnelle, la Commission tient compte des rapports du groupe de coopération et du réseau des CSIRT sur l'expérience acquise au niveau tant stratégique qu'opérationnel. Dans son réexamen, la Commission évalue en outre les listes figurant aux annexes II et III ainsi que la cohérence de l'identification des opérateurs de services essentiels et des services dans les secteurs visés à l'annexe II. Le premier rapport est présenté au plus tard le 9 mai 2021.

Article 24

Mesures transitoires

1. Sans préjudice de l'article 25 et afin d'offrir aux États membres des possibilités supplémentaires de coopération appropriée au cours de la période de transposition, le groupe de coopération et le réseau des CSIRT commencent à s'acquitter des tâches définies respectivement à l'article 11, paragraphe 3, et à l'article 12, paragraphe 3, au plus tard le 9 février 2017.

2. Au cours de la période comprise entre le 9 février 2017 et le 9 novembre 2018, et aux fins d'aider les États membres à adopter une approche cohérente dans le processus d'identification des opérateurs de services essentiels, le groupe de coopération discute du processus, ainsi que du contenu et du type des mesures nationales visant à identifier les opérateurs de services essentiels dans un secteur spécifique, conformément aux critères énoncés aux articles 5 et 6. Le groupe de coopération discute en outre, à la demande d'un État membre, des projets spécifiques de mesures nationales élaborés par cet État membre en vue d'identifier les opérateurs de services essentiels dans un secteur spécifique, conformément aux critères énoncés aux articles 5 et 6.

3. Au plus tard le 9 février 2017, et aux fins du présent article, les États membres assurent une représentation appropriée au sein du groupe de coopération et du réseau des CSIRT.

Article 25

Transposition

1. Les États membres adoptent et publient, au plus tard le 9 mai 2018, les dispositions législatives, réglementaires et administratives nécessaires pour se conformer à la présente directive. Ils en informent immédiatement la Commission.

Ils appliquent ces dispositions à partir du 10 mai 2018.

Lorsque les États membres adoptent ces dispositions, celles-ci contiennent une référence à la présente directive ou sont accompagnées d'une telle référence lors de leur publication officielle. Les modalités de cette référence sont arrêtées par les États membres.

2. Les États membres communiquent à la Commission le texte des dispositions essentielles de droit interne qu'ils adoptent dans le domaine régi par la présente directive.

Article 26

Entrée en vigueur

La présente directive entre en vigueur le vingtième jour suivant celui de sa publication au *Journal officiel de l'Union européenne*.

Article 27

Destinataires

Les États membres sont destinataires de la présente directive.

Fait à Strasbourg, le 6 juillet 2016.

Par le Parlement européen
Le président
M. SCHULZ
Par le Conseil
Le président
I. KORČOK

(1) JO C 271 du 19.9.2013, p. 133.

(2) Position du Parlement européen du 13 mars 2014 (non encore parue au Journal officiel) et position du Conseil en première lecture du 17 mai 2016 (non encore parue au Journal officiel). Position du Parlement européen du 6 juillet 2016 (non encore parue au Journal officiel).

(3) Directive 2002/21/CE du Parlement européen et du Conseil du 7 mars 2002 relative à un cadre réglementaire commun pour les réseaux et services de communications électroniques (directive «cadre») (JO L 108 du 24.4.2002, p. 33).

(4) Règlement (UE) n° 910/2014 du Parlement européen et du Conseil du 23 juillet 2014 sur l'identification électronique et les services de confiance pour les transactions électroniques au sein du marché intérieur et abrogeant la directive 1999/93/CE (JO L 257 du 28.8.2014, p. 73).

(5) Décision 2013/488/UE du Conseil du 23 septembre 2013 concernant les règles de sécurité aux fins de la protection des informations classifiées de l'Union européenne (JO L 274 du 15.10.2013, p. 1).

(6) JO C 352 du 7.10.2014, p. 4.

(7) Règlement (UE) n° 526/2013 du Parlement européen et du Conseil du 21 mai 2013 concernant l'Agence européenne chargée de la sécurité des réseaux et de l'information (ENISA) et abrogeant le règlement (CE) n° 460/2004 (JO L 165 du 18.6.2013, p. 41).

(8) Règlement (UE) n° 1025/2012 du Parlement européen et du Conseil du 25 octobre 2012 relatif à la normalisation européenne, modifiant les directives 89/686/CEE et 93/15/CEE du Conseil ainsi que les directives 94/9/CE, 94/25/CE, 95/16/CE, 97/23/CE, 98/34/CE, 2004/22/CE, 2007/23/CE, 2009/23/CE et 2009/105/CE du Parlement européen et du Conseil et abrogeant la décision 87/95/CEE du Conseil et la décision n° 1673/2006/CE du Parlement européen et du Conseil (JO L 316 du 14.11.2012, p. 12).

(9) Règlement (UE) n° 182/2011 du Parlement européen et du Conseil du 16 février 2011 établissant les règles et principes généraux relatifs aux modalités de contrôle par les États membres de l'exercice des compétences d'exécution par la Commission (JO L 55 du 28.2.2011, p. 13).

([10]) Directive 95/46/CE du Parlement européen et du Conseil du 24 octobre 1995 relative à la protection des personnes physiques à l'égard du traitement des données à caractère personnel et à la libre circulation de ces données (JO L 281 du 23.11.1995, p. 31).

([11]) Règlement (CE) n° 45/2001 du Parlement européen et du Conseil du 18 décembre 2000 relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel par les institutions et organes communautaires et à la libre circulation de ces données (JO L 8 du 12.1.2001, p. 1).

([12]) Règlement (CE) n° 1049/2001 du Parlement européen et du Conseil du 30 mai 2001 relatif à l'accès du public aux documents du Parlement européen, du Conseil et de la Commission (JO L 145 du 31.5.2001, p. 43).

([13]) JO C 32 du 4.2.2014, p. 19.

([14]) Directive 2008/114/CE du Conseil du 8 décembre 2008 concernant le recensement et la désignation des infrastructures critiques européennes ainsi que l'évaluation de la nécessité d'améliorer leur protection (JO L 345 du 23.12.2008, p. 75).

([15]) Directive 2011/93/UE du Parlement européen et du Conseil du 13 décembre 2011 relative à la lutte contre les abus sexuels et l'exploitation sexuelle des enfants, ainsi que la pédopornographie et remplaçant la décision-cadre 2004/68/JAI du Conseil (JO L 335 du 17.12.2011, p. 1).

([16]) Directive 2013/40/UE du Parlement européen et du Conseil du 12 août 2013 relative aux attaques contre les systèmes d'information et remplaçant la décision-cadre 2005/222/JAI du Conseil (JO L 218 du 14.8.2013, p. 8).

([17]) Directive (UE) 2015/1535 du Parlement européen et du Conseil du 9 septembre 2015 prévoyant une procédure d'information dans le domaine des réglementations techniques et des règles relatives aux services de la société de l'information (JO L 241 du 17.9.2015, p. 1).

([18]) Directive 2013/11/UE du Parlement européen et du Conseil du 21 mai 2013 relative au règlement extrajudiciaire des litiges de consommation et modifiant le règlement (CE) n° 2006/2004 et la directive 2009/22/CE (directive relative au RELC) (JO L 165 du 18.6.2013, p. 63).

([19]) Recommandation 2003/361/CE de la Commission du 6 mai 2003 concernant la définition des micro, petites et moyennes entreprises (JO L 124 du 20.5.2003, p. 36).

ANNEXE I

OBLIGATIONS ET TÂCHES DES CENTRES DE RÉPONSE AUX INCIDENTS DE SÉCURITÉ INFORMATIQUE (CSIRT)

Les obligations et tâches des CSIRT doivent être correctement et clairement définies sur la base d'une politique ou réglementation nationale. Elles comprennent les éléments suivants:

1) Obligations des CSIRT

   a) Les CSIRT doivent veiller à un niveau élevé de disponibilité de leurs services de communication en évitant les points uniques de défaillance et ils doivent disposer de plusieurs moyens pour être contactés et contacter autrui à tout moment. De plus, les canaux de communication doivent être clairement précisés et bien connus des partenaires et collaborateurs.

   b) Les locaux des CSIRT et les systèmes d'information utilisés doivent se trouver sur des sites sécurisés.

   c) Continuité des opérations:

      i) les CSIRT sont dotés d'un système approprié de gestion et de routage des demandes afin de faciliter les transferts;

      ii) les CSIRT sont dotés des effectifs adéquats afin de pouvoir garantir une disponibilité permanente;

iii) les CSIRT s'appuient sur une infrastructure dont la continuité est garantie. À cette fin, des systèmes redondants et un espace de travail de secours sont disponibles.

d) Les CSIRT ont la possibilité de participer, lorsqu'ils le souhaitent, aux réseaux de coopération internationale.

2) Tâches des CSIRT

a) Les tâches des CSIRT comprennent au moins les éléments suivants:

i) suivi des incidents au niveau national;

ii) activation du mécanisme d'alerte précoce, diffusion de messages d'alerte, annonces et diffusion d'informations sur les risques et incidents auprès des parties intéressées;

iii) intervention en cas d'incident;

iv) analyse dynamique des risques et incidents et conscience situationnelle;

v) participation au réseau des CSIRT.

b) Les CSIRT établissent des relations de coopération avec le secteur privé.

c) Pour faciliter la coopération, les CSIRT promeuvent l'adoption et l'utilisation de pratiques communes normalisées pour:

i) les procédures de gestion des risques et incidents;

ii) les systèmes de classification des incidents, risques et informations.

ANNEXE II

TYPES D'ENTITÉS AUX FINS DE L'ARTICLE 4, POINT 4)

Secteur	Sous-secteur	Type d'entités
1.Énergie	a)Électricité	—Entreprises d'électricité au sens de l'article 2, point 35), de la directive 2009/72/CE du Parlement européen et du Conseil ([1]), qui remplit la fonction de «fourniture» au sens de l'article 2, point 19), de ladite directive
		—Gestionnaires de réseau de distribution au sens de l'article 2, point 6), de la directive 2009/72/CE
		—Gestionnaires de réseau de transport au sens de l'article 2, point 4), de la directive 2009/72/CE
	b)Pétrole	—Exploitants d'oléoducs

		—Exploitants d'installations de production, de raffinage, de traitement, de stockage et de transport de pétrole
	c)Gaz	—Entreprises de fourniture au sens de l'article 2, point 8), de la directive 2009/73/CE du Parlement européen et du Conseil ([2])
		—Gestionnaires de réseau de distribution au sens de l'article 2, point 6), de la directive 2009/73/CE
		—Gestionnaires de réseau de transport au sens de l'article 2, point 4), de la directive 2009/73/CE
		—Gestionnaires d'installation de stockage au sens de l'article 2, point 10), de la directive 2009/73/CE
		—Gestionnaires d'installation de GNL au sens de l'article 2, point 12), de la directive 2009/73/CE
		—Entreprises de gaz naturel au sens de l'article 2, point 1), de la directive 2009/73/CE
		—Exploitants d'installations de raffinage et de traitement de gaz naturel
2.Transports	a)Transport aérien	—Transporteurs aériens au sens de l'article 3, point 4), du règlement (CE) n° 300/2008 du Parlement européen et du Conseil ([3])
		—Entités gestionnaires d'aéroports au sens de l'article 2, point 2), de la directive 2009/12/CE du Parlement européen et du

			Conseil ([4]), aéroports au sens de l'article 2, point 1), de ladite directive, y compris les aéroports du réseau central énumérés à l'annexe II, section 2, du règlement (UE) n° 1315/2013 du Parlement européen et du Conseil ([5]), et entités exploitant les installations annexes se trouvant dans les aéroports
			—Services du contrôle de la circulation aérienne au sens de l'article 2, point 1), du règlement (CE) n° 549/2004 du Parlement européen et du Conseil ([6])
		b)Transport ferroviaire	—Gestionnaires de l'infrastructure au sens de l'article 3, point 2), de la directive 2012/34/UE du Parlement européen et du Conseil ([7])
			—Entreprises ferroviaires au sens de l'article 3, point 1), de la directive 2012/34/UE, y compris les exploitants d'installations de services au sens de l'article 3, point 12), de la directive 2012/34/UE
		c)Transport par voie d'eau	—Sociétés de transport terrestre, maritime et côtier de passagers et de fret au sens de l'annexe I du règlement (CE) n° 725/2004 du Parlement européen et du Conseil ([8]), à l'exclusion des navires exploités à titre individuel par ces sociétés
			—Entités gestionnaires des ports au sens de l'article 3, point 1), de la directive 2005/65/CE du

		Parlement européen et du Conseil ([9]), y compris les installations portuaires au sens de l'article 2, point 11), du règlement (CE) n° 725/2004, ainsi que les entités exploitant des ateliers et des équipements à l'intérieur des ports
		—Exploitants de services de trafic maritime au sens de l'article 3, point o), de la directive 2002/59/CE du Parlement européen et du Conseil ([10])
	d)Transport routier	—Autorités routières au sens de l'article 2, point 12), du règlement délégué (UE) 2015/962 de la Commission ([11]), chargées du contrôle de gestion du trafic
		—Exploitants de systèmes de transport intelligents au sens de l'article 4, point 1), de la directive 2010/40/UE du Parlement européen et du Conseil ([12])
3.Banques		Établissements de crédit au sens de l'article 4, point 1), du règlement (UE) n° 575/2013 du Parlement européen et du Conseil ([13])
4.Infrastructures de marchés financiers		—Exploitants de plate-forme de négociation au sens de l'article 4, point 24), de la directive 2014/65/UE du Parlement européen et du Conseil ([14])
		—Contreparties centrales au sens de l'article 2, point 1), du règlement (UE) n° 648/2012

		du Parlement européen et du Conseil ([15])
5.Secteur de la santé	Établissements de soins de santé (y compris les hôpitaux et les cliniques privées)	Prestataires de soins de santé au sens de l'article 3, point g), de la directive 2011/24/UE du Parlement européen et du Conseil ([16])
6.Fourniture et distribution d'eau potable		Fournisseurs et distributeurs d'eaux destinées à la consommation humaine au sens de l'article 2, point 1) a), de la directive 98/83/CE du Conseil ([17]), à l'exclusion des distributeurs pour lesquels la distribution d'eaux destinées à la consommation humaine ne constitue qu'une partie de leur activité générale de distribution d'autres produits et biens qui ne sont pas considérés comme des services essentiels
7.Infrastructures numériques		—IXP
		—Fournisseurs de services DNS
		—Registres de noms de domaines de haut niveau

([1]) Directive 2009/72/CE du Parlement européen et du Conseil du 13 juillet 2009 concernant des règles communes pour le marché intérieur de l'électricité et abrogeant la directive 2003/54/CE (JO L 211 du 14.8.2009, p. 55).

([2]) Directive 2009/73/CE du Parlement européen et du Conseil du 13 juillet 2009 concernant des règles communes pour le marché intérieur du gaz naturel et abrogeant la directive 2003/55/CE (JO L 211 du 14.8.2009, p. 94).

([3]) Règlement (CE) n° 300/2008 du Parlement européen et du Conseil du 11 mars 2008 relatif à l'instauration de règles communes dans le domaine de la sûreté de l'aviation civile et abrogeant le règlement (CE) n° 2320/2002 (JO L 97 du 9.4.2008, p. 72).

([4]) Directive 2009/12/CE du Parlement européen et du Conseil du 11 mars 2009 sur les redevances aéroportuaires (JO L 70 du 14.3.2009, p. 11).

([5]) Règlement (UE) n° 1315/2013 du Parlement européen et du Conseil du 11 décembre 2013 sur les orientations de l'Union pour le développement du réseau transeuropéen de transport et abrogeant la décision n° 661/2010/UE (JO L 348 du 20.12.2013, p. 1).

([6]) Règlement (CE) n° 549/2004 du Parlement européen et du Conseil du 10 mars 2004 fixant le cadre pour la réalisation du ciel unique européen («règlement-cadre») (JO L 96 du 31.3.2004, p. 1).

([7]) Directive 2012/34/UE du Parlement européen et du Conseil du 21 novembre 2012 établissant un espace ferroviaire unique européen (JO L 343 du 14.12.2012, p. 32).

([8]) Règlement (CE) n° 725/2004 du Parlement européen et du Conseil du 31 mars 2004 relatif à l'amélioration de la sûreté des navires et des installations portuaires (JO L 129 du 29.4.2004, p. 6).

([9]) Directive 2005/65/CE du Parlement européen et du Conseil du 26 octobre 2005 relative à l'amélioration de la sûreté des ports (JO L 310 du 25.11.2005, p. 28).

([10]) Directive 2002/59/CE du Parlement européen et du Conseil du 27 juin 2002 relative à la mise en place d'un système communautaire de suivi du trafic des navires et d'information, et abrogeant la directive 93/75/CEE du Conseil (JO L 208 du 5.8.2002, p. 10).

([11]) Règlement délégué (UE) 2015/962 de la Commission du 18 décembre 2014 complétant la directive 2010/40/UE du Parlement européen et du Conseil en ce qui concerne la mise à disposition, dans l'ensemble de l'Union, de services d'informations en temps réel sur la circulation (JO L 157 du 23.6.2015, p. 21).

([12]) Directive 2010/40/UE du Parlement européen et du Conseil du 7 juillet 2010 concernant le cadre pour le déploiement de systèmes de transport intelligents dans le domaine du transport routier et d'interfaces avec d'autres modes de transport (JO L 207 du 6.8.2010, p. 1).

([13]) Règlement (UE) n° 575/2013 du Parlement européen et du Conseil du 26 juin 2013 concernant les exigences prudentielles applicables aux établissements de crédit et aux entreprises d'investissement et modifiant le règlement (UE) n° 648/2012 (JO L 176 du 27.6.2013, p. 1).

([14]) Directive 2014/65/UE du Parlement européen et du Conseil du 15 mai 2014 concernant les marchés d'instruments financiers et modifiant la directive 2002/92/CE et la directive 2011/61/UE (JO L 173 du 12.6.2014, p. 349).

([15]) Règlement (UE) n° 648/2012 du Parlement européen et du Conseil du 4 juillet 2012 sur les produits dérivés de gré à gré, les contreparties centrales et les référentiels centraux (JO L 201 du 27.7.2012, p. 1).

([16]) Directive 2011/24/UE du Parlement européen et du Conseil du 9 mars 2011 relative à l'application des droits des patients en matière de soins de santé transfrontaliers (JO L 88 du 4.4.2011, p. 45).

([17]) Directive 98/83/CE du Conseil du 3 novembre 1998 relative à la qualité des eaux destinées à la consommation humaine (JO L 330 du 5.12.1998, p. 32).

ANNEXE III

TYPES DE SERVICES NUMÉRIQUES AUX FINS DE L'ARTICLE 4, POINT 5)

1. Place de marché en ligne
2. Moteurs de recherche en ligne
3. Service d'informatique en nuage

Top

EUR-Lex

This site is managed by the Publications Office of the European Union

Need help?

Help pages

Contact

Sitemap

Legal

Legal notice
Cookies policy
Accessibility
Privacy statement

Information

About EUR-Lex
Newsletter
Useful links

Other services

European Data
EU tenders
EU research results
EU Whoiswho
EU publications

N-Lex
EU Law Tracker

EU

Discover more on europa.eu

Contact the EU

Call us 00 800 6 7 8 9 10 11
Use other telephone options
Write to us via our contact form
Meet us at one of the EU centres

Social media

Search for EU social media channels

Legal

Languages on our websites
Privacy policy
Legal notice
Cookies

EU institutions

European Parliament
European Council
Council of the European Union
European Commission
Court of Justice of the European Union (CJEU)
European Central Bank (ECB)
European Court of Auditors
European External Action Service (EEAS)
European Economic and Social Committee
European Committee of Regions (CoR)
European Investment Bank
European Ombudsman
European Data Protection Supervisor (EDPS)
European Data Protection Board
European Personnel Selection Office
Publications Office of the European Union
Agencies